

Spott iOS 原生 App

+ Web 全栈开发文档

面向 10 万用户的高可用、可同步、可持续演进研发基线

SWIFT 6.3 • NEXT.JS 16.2 • NESTJS 11 • POSTGRESQL 18.4

产品	Spott - 日本同城活动
目标	发现活动，遇见同好
交付范围	iOS 原生 / Web-PWA / Backend / Ops / PostgreSQL
数据架构	PostgreSQL 唯一权威源 • Web 与 iOS 双向同步
版本	V1.0 • 2026-07-15

DESIGN DIRECTION

Tokyo Afterglow

借鉴 Luma 的高级感与内容优先原则，建立 Spott 独立的都市活动设计语言。

文档控制

文档说明

本文以《Spott-日本同城活动 产品功能文档 V1 | 全功能版》为产品需求基线，将产品规则转换为可执行的技术架构、数据模型、同步协议、端侧规格、API 契约、状态机、测试方案与发布计划。若本文与经审批的产品规则冲突，以变更记录中最新的决策为准；任何积分数值、审核阈值、活动规则、免费额度和运营阶段均不得硬编码在客户端。

本文中的“同步”不是简单的多端刷新：PostgreSQL 是唯一权威业务数据库，iOS 和 Web 使用同一身份、同一业务 ID、同一状态机与同一 API 契约；所有成功写入必须可被另一端通过增量同步或实时事件感知，并能在断网、重试、并发修改和服务降级时保持可恢复、可审计和不重复执行。

版本与复核

项目	内容
文档版本	V1.0 开发基线版
产品来源	Spott 产品功能文档 V1 全功能版（2026-07-13）
技术范围	iOS、Web/PWA、Backend API、PostgreSQL、运营后台、基础设施
首发市场	日本全国；东京及首都圈重点运营
默认语言	简体中文；数据结构预留繁体中文、日语、英语
技术复核	开发者按本文门禁自检；隐私、支付、税务、内容安全与 App Review 等高风险事项引入专业复核
法务边界	本文不构成日本法律、税务或会计意见；上线前需由日本专业人士复核

阅读路径

- 产品、设计与运营视角：重点阅读第 1、2、3、4、12、18、20 章。
- iOS 与 Web 实现：重点阅读第 4、5、6、8、9、10、12、16 章。
- 后端、数据与基础设施：重点阅读第 5、6、7、8、11、13、15、17 章。
- 测试、安全与上线：重点阅读第 2、6、12、13、14、16、20 章。

目录

共 20 个主章节与 4 个附录；详细层级可在 Word 导航窗格中查看。

章节	主题	章节	主题
1.	执行摘要	13.	安全、隐私与合规工程
2.	产品需求基线与范围	14.	非功能要求与 SLO
3.	视觉与体验设计方向	15.	埋点、监控与数据治理
4.	信息架构与页面规格	16.	测试与质量保证
5.	总体系统架构	17.	DevOps、迁移与发布
6.	Web 与 iOS 数据同步设计	18.	个人开发路线与交付门禁
7.	PostgreSQL 数据架构	19.	主要风险与缓解
8.	API 契约设计	20.	验收与需求追踪
9.	iOS 原生开发规范	附录 A.	配置中心键建议
10.	Web 与运营后台开发规范	附录 B.	稳定错误码目录
11.	后端模块详细设计	附录 C.	外部参考与复核日期
12.	核心状态机与业务规则	附录 D.	最终技术原则

1. 执行摘要

1.1 建设目标

Spott 是面向在日华人的本地活动发现、报名、组织与兴趣社群平台。同一账号同时具备参与者与组织者能力，访客可以无登录浏览，高信任动作再触发日本手机号验证。V1 的工程目标不是堆叠页面，而是建立三条可长期扩展的可信闭环：

- 1. 发现闭环：地区与兴趣推荐 → 活动详情 → 收藏/分享 → 报名或候补。
- 2. 履约闭环：发布 → 审核 → 报名占位 → 通知 → 签到 → 反馈 → 再次参与。
- 3. 社区闭环：一次活动 → 关联群组 → 公告与后续活动 → 长期复购关系。

1.2 技术结论

领域	结论
iOS	Swift 6.3 + Xcode 26.6; SwiftUI 为主，必要位置桥接 UIKit; 最低 iOS 17; 不使用 Flutter、React Native 或 WebView 承载核心业务
Web	Next.js 16.2 Stable + React 19.2 + TypeScript 6.0; 公开页 SSR/ISR，登录后工作台使用服务端数据获取与客户端交互; 支持响应式与基础 PWA
Backend	Node.js 24 LTS + NestJS 11 + Fastify 5; 模块化单体起步; OpenAPI 为跨端契约; 异步 Worker 承担通知与任务
数据库	PostgreSQL 18.4 稳定版优先; 启用 PostGIS、pg_trgm、citext、pgcrypto; 不使用 PostgreSQL 19 Beta 或其他预览特性
同步	API 写入 + 事务 Outbox + 全局变更序列 + WebSocket/SSE 唤醒 + 增量 Pull; 关键写入强一致，展示类数据最终一致
本地数据	iOS 使用 SwiftData/SQLite 缓存与离线操作队列; Web 使用 Query Cache + IndexedDB 保存可恢复草稿，不将浏览器缓存视为权威数据
基础设施	日本区域托管; RDS PostgreSQL Multi-AZ、Redis、对象存储/CDN、消息队列、容器化 API/Worker、集中日志与指标
产品差异	借鉴 Luma 的内容优先、轻量创建、富封面、宽松留白和高完成度; 不复制其品

领域	结论
	牌、导航、页面结构、主题资产或交互细节

1.2.1 技术版本采用规则

本表是 2026-07-15 的已核验基线。真正开工时执行一次 Compatibility Gate：只升级到已经 General Availability、官方支持、关键依赖兼容、云服务可托管且通过回归的最新稳定版本。“最新”不等于 Beta/RC/Nightly。生产 Node.js 使用 24 LTS，不使用当时仍为 Current 的 Node.js 26；Web 使用 Next.js 16.2 Stable，不使用 16.3 Preview；数据库使用 PostgreSQL 18.x，不使用 PostgreSQL 19 Beta。

层	开发基线	选择理由	升级策略
Apple 工具链	Xcode 26.6、Swift 6.3、iOS 26.6 SDK	2026-07 最新正式工具链与语言；严格并发、现代 SwiftUI	Xcode Patch 及时跟进；年度 SDK 升级设兼容分支
iOS 部署	Minimum iOS 17，使用 Availability 包装新 API	覆盖面与现代 API 平衡；保留 iOS 26 原生增强	每年按日本活跃设备占比复核最低版本
Web	Next.js 16.2、React 19.2、TypeScript 6.0	最新稳定主流组合；SSR、RSC、严格类型、生态成熟	Patch 自动化；Minor 月度；Major 半年评审
JS Runtime	Node.js 24 LTS	官方建议生产使用 LTS；支持周期明确	只在新版本进入 LTS 后升级
Backend	NestJS 11 + Fastify 5	模块化、DI、OpenAPI、测试与企业生态成熟；Fastify 高吞吐	不跟随未发布主干；升级前跑契约与负载基准
Package/Monorepo	pnpm 最新稳定 + Turborepo 最新稳定	确定性 Lockfile、Workspace、缓存构建	Corepack 锁版本；Renovate 分组升级
Data Access	Kysely/typed SQL + node-postgres；迁移使用显式 SQL	完整支持 PostGIS、部分索引、锁、RLS、账本事务	不让 ORM 隐藏关键 SQL；SQL 需 Explain 与 Review
Database	PostgreSQL 18.4	当前正式主版本，性能与大版本升级能力完善	Patch 30 天内；Major 每年评估、隔离演练
Cache	托管 Valkey/Redis 兼容稳定版	多可用区、成熟客户端、缓存可重建	只使用托管服务支持的稳定主版本
Contract	OpenAPI 3.1 + 代码生成	iOS/Web/Backend 单一契约、可	Breaking Change 必须新 API

层	开发基线	选择理由	升级策略
		做兼容门禁	版本
Observability	OpenTelemetry + Prometheus/Grafana + Sentry 等价能力	开放标准、Trace/Metric/Log 关联	避免业务代码绑定单一供应商 SDK

1.3 一致性分级

- 强一致：活动名额、报名/候补顺序、签到、积分扣减与冲正、商店订单、账号限制、审核状态。
- 读己之写：用户提交资料、收藏、关注、草稿、通知已读后，本端立即显示成功状态；服务器确认后生成版本。
- 最终一致：推荐流、浏览量、聚合成就进度、统计报表、分享归因聚合、公开到场率区间。
- 不允许离线提交：积分购买、最终报名占位、动态签到码验证、账号合并、敏感后台操作。
- 允许离线排队：资料编辑、活动草稿、反馈草稿、通知已读、收藏/取消收藏；恢复网络后按幂等键重放。

1.4 V1 成功标准

- Web 端修改公开资料、收藏、报名状态后，iOS 前台 3 秒内可见；后台恢复或离线重连后 30 秒内收敛。
- 同一活动 500 个并发报名请求不超卖、不生成重复有效报名、不重复扣积分。
- 积分所有业务均采用不可变双分录账本；重复请求、超时重试和重复商店回调不重复入账。
- P0 核心链路月可用性目标 99.9%；API 读取 p95 小于 300ms，关键写入 p95 小于 500ms（不含第三方短信与商店延迟）。
- 公开活动页 LCP 目标小于 2.5 秒；iOS 冷启动到可浏览缓存内容目标小于 1.8 秒（主流近三年设备）。
- 关键页面满足 WCAG 2.2 AA 与 iOS Dynamic Type/VoiceOver 基础要求。

2. 产品需求基线与范围

2.1 产品原则

- 低门槛浏览，高信任动作验证：不以登录墙阻断发现。
- 同一自然人只拥有一个主账号，可同时参与和组织活动。
- 收费活动由组织者在 App 外自行收款；Spott 不代收、不结算、不担保、不抽成。
- 平台积分只兑换 Spott 自身数字功能，与活动费完全分离。
- 免费积分与付费积分分账，任何金额和阈值均可后台配置并保留历史版本。
- V1 不做用户私信和无限制实时群聊；群组以活动、公告和受控评论为核心。
- 安全限制优先于账号状态、角色权限、群组/活动权限和积分余额。

2.2 角色与权限

角色	核心能力	主要限制
访客	浏览发现、搜索、活动详情、群组和公开主页	不能收藏、关注、报名、评论、发布或消耗积分
注册用户	完善资料、收藏、关注、领取积分、设置通知	未验证日本手机号时不能报名、发布或创建群组
已验证用户	报名、候补、签到、评价、创建群组、发布活动	受账号状态、风控和积分余额限制
局头/群主	管理活动、报名名单、签到、群组、管理员和公告	不得获取非必要敏感信息
认证局头	认证标识、更高额度、部分增强工具	初期关闭；认证不构成平台担保
品牌账号	品牌主页、品牌活动、增强数据与推广工具	P2；人工审核与独立协议
平台运营	审核、下架、配置、积分申请、客服、数据查看	按岗位最小权限，敏感操作需审批与审计

2.3 功能优先级

优先级	必须交付	默认开关策略
P0 上线前	账号、手机验证、发现、搜索、详情、发布、审核、报名、候补、签到、群组、积分双账本、举报、运营后台、核心埋点、Web/iOS 同步	地区、分类、积分价格、奖励与免费额度可配置
P1 上线期	成就、分享卡、AI 海报、iOS 付费积分内购、置顶、群组扩容、完整通知	内购入口、稳定期详情收费、工具包通过功能开关逐步开放
P2 数据稳定后	VIP、大组织者、品牌账号、增强数据、广告赞助、多语言	按组织者、地区、版本和用户分组灰度

2.4 明确不做

- V1 不开发 Android 客户端；后端 API、ID、通知和本地化模型不得阻止未来 Android 接入。
- 不在 App 内处理活动费、退款或向局头结算；不允许积分抵扣活动费或提现。
- 不做开放式陌生人私信、无限制群聊、公开自由文本评分榜、充值排名。
- 不以 CloudKit、Firebase Firestore 或浏览器本地存储作为业务主数据库。
- 不允许客户端直接连接 PostgreSQL，也不向客户端暴露数据库账号、表结构或管理密钥。
- 不在客户端硬编码积分价格、风控阈值、活动分类、审核规则或通知模板。

2.5 需求追踪编号

本文使用 REQ-域-序号 作为需求编号，例如 REQ-AUTH-001。提交代码、测试用例、埋点事件和发布记录应引用对应编号。顶级域包括 AUTH、DISC、EVT、REG、CHK、GRP、ACH、PTS、NOT、SHR、SAFE、ADM、DATA、SYNC、NFR。

3. 视觉与体验设计方向

3.1 参考原则：像 Luma 一样高级，但不是 Luma

Luma 公开产品强调发现本地活动、快速创建漂亮活动页、封面主题、报名、分享、签到以及 iOS/Web 跨端体验。Spott 借鉴的是“内容先于平台宣传、创建过程短、视觉留白充分、活动封面具有主角感、状态与下一步清晰”的体验原则，而不是复刻具体界面。

Spott 的独立识别建立在“Tokyo Afterglow / 东京余光”设计语言上：夜色墨黑、米纸暖白、暮光紫、珊瑚橙与薄荷绿构成克制而有生命力的城市色谱；组件使用柔和但不夸张的圆角、微弱高光边缘、地图与时间信息的结构化排版，以及类似镜头光斑的“Spotlight”品牌动效。整体应像一本会动的城市活动杂志，而不是票务后台或社交信息流。

3.2 品牌设计令牌

令牌	Light	Dark	用途
Canvas	#F7F5F0	#0E1014	页面底色，避免纯白/纯黑疲劳
Surface	#FFFFFF	#171A20	卡片、浮层、表单
Ink	#17181C	#F7F6F2	主文本
Muted	#6F737C	#A7ACB7	次级说明
Twilight	#6E5BE7	#9B8CFF	主品牌与主要按钮
Coral	#FF745F	#FF866F	时间、紧迫状态、重点行动
Mint	#3DBD91	#51D4A5	成功、可报名、已签到
Amber	#D99A2B	#F0B84F	候补、审核、注意
Danger	#D84B5B	#FF6B79	取消、拒绝、风险
Divider	#E6E2DA	#2B3038	分隔与边界

3.3 排版、圆角与间距

- iOS 使用系统字体族：拉丁 SF Pro，简中自动回退 PingFang SC，日文回退 Hiragino Sans；正文不强制自定义字体，保证 Dynamic Type。
- Web 使用 Inter Variable + Noto Sans SC + Noto Sans JP；数字与时间启用 tabular numerals。
- 标题层级：Display 32/38、Title 24/30、Section 20/26、Body 16/24、Meta 13/18、Caption 12/16。
- 间距基线：4、8、12、16、24、32、48、64；避免任意 5/7/11 像素漂移。
- 圆角：控件 12、卡片 18、封面容器 24、全屏面板 28；胶囊仅用于状态或筛选。
- 阴影不作为主要分层手段；优先使用背景明度、1px 高光边和适度模糊材质。

3.4 动效与触感

- 快反馈 120ms：按钮按下、图标状态、收藏切换。
- 标准过渡 220ms：筛选展开、卡片状态、底部面板。
- 叙事过渡 360ms：封面到详情的共享元素、成功状态、成就达成。
- iOS 使用 `spring(response: 0.42, dampingFraction: 0.86)` 作为主弹簧；Web 使用物理曲线近似而非夸张弹跳。
- Reduce Motion 开启后取消视差、共享元素缩放和连续光斑，只保留淡入淡出。
- 成功报名、签到、发布成功使用轻触觉；风险与不可逆操作使用警告触觉；滚动和普通导航不滥用触觉。

3.5 活动封面与图片系统

- 列表主封面 16:9，详情页可使用 4:3 视觉裁切；原图保留焦点坐标，服务端生成多规格 AVIF/WebP/JPEG。
- 上传前端压缩只用于预览，原始合规图片仍需后台生成标准衍生图；所有图片写入内容哈希与审核状态。
- 无图状态不使用随机库存图：按分类生成可控的品牌默认封面，包含纹理、时间和分类符号。
- 封面上的文字不得成为唯一信息来源；活动标题、时间与地点必须以可读文本重复呈现。

3.6 差异化检查清单

- 不使用 Luma 商标、字体、图标、海报模板、主题名称或品牌色。
- 不逐页对应其信息架构，不复制其导航标签、卡片比例组合或注册弹窗结构。
- 所有视觉组件由 Spott Design Tokens 驱动，iOS 与 Web 共享语义令牌而非像素复制。
- 优先呈现日本本地时间、都道府县/城市、交通与集合信息，形成 Spott 的地域特征。
- 收费活动明确展示 App 外自收与退款边界，这是 Spott 的核心产品区别。

4. 信息架构与页面规格

4.1 iOS 主导航

Tab	目标	核心内容
发现	10 秒内找到相关活动	地区、搜索、推荐模块、分类、活动流、地图切换
我的活动	承载参与闭环	即将开始、待确认、候补、过去、票码/签到、日历
创建	最短路径发布	活动草稿、快速创建、历史复制、群组创建
社群	长期关系	已加入群组、关注局头、公告、群组活动
我的	身份与信任	资料、成就、积分、通知、局头工作台、设置

“创建”使用独立突出但不悬浮遮挡内容的中间入口。用户身份不切换账号，只切换任务上下文；局头工作台从“我的”和已发布活动进入。

4.2 Web 顶层结构

区域	路由示例	说明
公开发现	/discover,/tokyo,/categories/{slug}	SSR/ISR，可索引；无登录墙
活动详情	/e/{publicSlug}	服务端渲染，开放图谱、结构化数据、分享归因
群组与主页	/g/{slug},/u/{handle}	公开资料、活动与关注入口
用户中心	/me/events,/me/wallet,/me/settings	登录后动态数据
局头工作台	/studio/events,/studio/groups,/studio/insights	桌面端高效批量管理
运营后台	/ops/*	独立部署入口、MFA、IP/设备策略、细粒度权限

4.3 核心页面清单

编号	页面	iOS	Web	关键状态
S01	发现首页	是	是	初始、定位未授权、空供给、缓存、离线、加载失败
S02	搜索与筛选	是	是	建议、历史、组合筛选、零结果、地图列表
S03	活动详情	是	是	可报名、待审核、候补、已满、截止、取消、下架、结束
S04	登录/注册	是	是	Apple、Google、邮箱验证码、账号合并
S05	日本手机号验证	是	是	发送、倒计时、错误、超限、重复绑定、申诉
S06	报名表	是	是	自动通过、审核制、候补、收费边界、积分确认
S07	我的票码/签到	是	Web 只展示	动态码、二维码、弱网、已签到、补签申请
S08	活动创建向导	是	是	草稿、自动保存、字段校验、预览、风险命中
S09	活动管理	是	是	名单、候补、签到、公告、修改、取消、复盘
S10	群组主页	是	是	公开、申请制、成员、禁言、满员、已移除
S11	群组管理	是	是	角色、审核、扩容、转让、解散
S12	个人主页	是	是	参与者、局头、成就隐藏、拉黑关系
S13	积分钱包	是	是	双余额、到期、流水、购买、负付费积分
S14	通知中心	是	是	未读、聚合、服务通知、静默设置
S15	举报/申诉	是	是	草稿、证据上传、提交、补充、处理结果

编号	页面	iOS	Web	关键状态
S16	运营审核队列	否	是	风险分级、认领、处理、复核、SLA
S17	运营配置	否	是	草稿、审批、灰度、生效、回滚、审计

4.4 发现首页规格

- 顶部首行只保留当前地区、搜索、通知与头像；地区由用户选择优先，位置权限为增强而非前置条件。
- 首屏必须出现至少一张真实活动卡，不以平台品牌 Banner 占据主要面积；运营 Banner 最多一个且标记“推广/运营推荐”。
- 推荐模块按今日、本周末、附近热门、兴趣、新活动、关注更新组织；模块顺序由服务端配置，不由客户端写死。
- 活动卡展示封面、标题、日期时间、城市/区域、费用、名额状态、局头与最多三个标签；精确地址永不出现在列表缓存。
- 骨架屏布局必须与真实卡片接近；缓存数据立即展示并以小型同步状态提示更新，不使用全屏旋转加载覆盖已有内容。
- 地图模式只加载当前视口内活动聚合点；缩放停止 300ms 后请求，避免连续网络风暴。

4.5 活动详情规格

- 详情头部采用大封面 + 日期徽标 + 状态，不使用沉重导航栏；滚动后标题折叠到导航区。
- 信息顺序：状态/标题 → 时间与日历 → 城市/集合范围 → 费用与边界 → 名额 → 局头信誉 → 介绍 → 风险/退款 → 群组 → 相似活动。
- 底部行动栏根据服务器返回的 `availableActions` 渲染，不由客户端根据时间自行猜测；金额、积分和状态更新时行动栏原子刷新。
- 精确地址只有 `registration.status in (confirmed, checked_in)` 且活动未被安全隐藏时返回；服务端不能只依赖前端遮罩。
- 收费活动固定显示“费用由组织者自行收取，Spott 不经手活动款”，并将收款主体、外部方式、付款时限、取消退款规则置于独立信息块。

4.6 发布向导规格

发布采用“先快后全”的双层结构：第一阶段创建可恢复草稿，只收标题、时间、地区、分类和封面；第二阶段按活动类型动态展开人数、报名、收费、风险、签到、群组 and 分享设置。提交前集中预览，不在每一步反复弹窗。

步骤	字段	校验责任
1 基本信息	分类、标题、封面、说明	客户端即时校验 + 服务端最终校验
2 时间地点	起止、截止、时区、城市、集合地址、公开级别	服务端统一时区与地址权限
3 报名设置	人数、自动/审核/邀请码、候补、问题、条件	容量与条件由服务端状态机执行
4 费用风险	免费/收费、金额、收款主体、外部方式、退款规则、风险声明	缺失即禁止提交；高风险进入人工审核
5 现场与社群	签到方式、关联群组、评论、分享图	动态码与权限由后端生成
6 预览提交	完整预览、风险词、积分冻结、确认	使用幂等键；成功返回审核单号

草稿每次字段失焦或 5 秒空闲后合并保存；本地保存 `draftRevision`，服务端保存 `version`。多端同时编辑时不静默覆盖：显示差异，允许选择“保留此设备”“使用云端”或逐字段合并。

4.7 报名与候补体验

- 报名前集中显示人数、问题、积分、收费边界、取消规则 and 风险提示；提交按钮文案包含结果，例如“消耗 10 积分并报名”。
- 自动通过活动提交成功才显示占位；审核制显示“待确认”，不得提前暴露精确地址。
- 满员竞态由后端返回 `CAPACITY_FULL` 与当前候补策略；用户可一键进入候补，但不得客户端自动替用户确认。
- 候补递补通知包含确认截止时间，倒计时以服务器时间为准；跨端确认只成功一次。
- 用户取消前显示积分退回结果；关键变更后拒绝继续参加时全额退回本次 Spott 报名积分。

4.8 空、错、弱网与权限状态

- 空状态必须给下一步：放宽筛选、切换地区、关注关键词、创建活动 or 查看缓存。
- 错误信息使用业务语言并保留错误编号；“失败，请重试”只可作为未知错误兜底。

- 对相机、位置、通知、照片、日历权限均先显示场景说明，再触发系统授权；拒绝后提供设置入口与无权限替代流程。
- 所有表单在网络错误后保留输入；重复点击由端侧防抖和服务端幂等共同处理。
- 离线时公开缓存可浏览，隐藏可能已变化的精确地址与动态签到码，禁止显示“已完成同步”的误导状态。

5. 总体系统架构

5.1 架构原则

- PostgreSQL 是唯一权威事实源；Redis、搜索索引、CDN、客户端缓存均可重建。
- V1 使用边界清晰的模块化单体，先保证事务完整和交付效率；只有出现独立扩缩容、故障隔离或团队边界需求时才拆服务。
- 客户端只能通过版本化 API 访问业务，不直接订阅数据库变更、不拼接 SQL、不信任本地推导的权限。
- 所有有副作用的公开写接口支持幂等；所有跨进程副作用通过事务 Outbox 驱动。
- 关键状态机由服务端执行；客户端渲染 `state` 与 `availableActions`，不复制业务规则。
- 个人信息、精确地址、投诉证据、积分和运营权限按数据等级隔离。

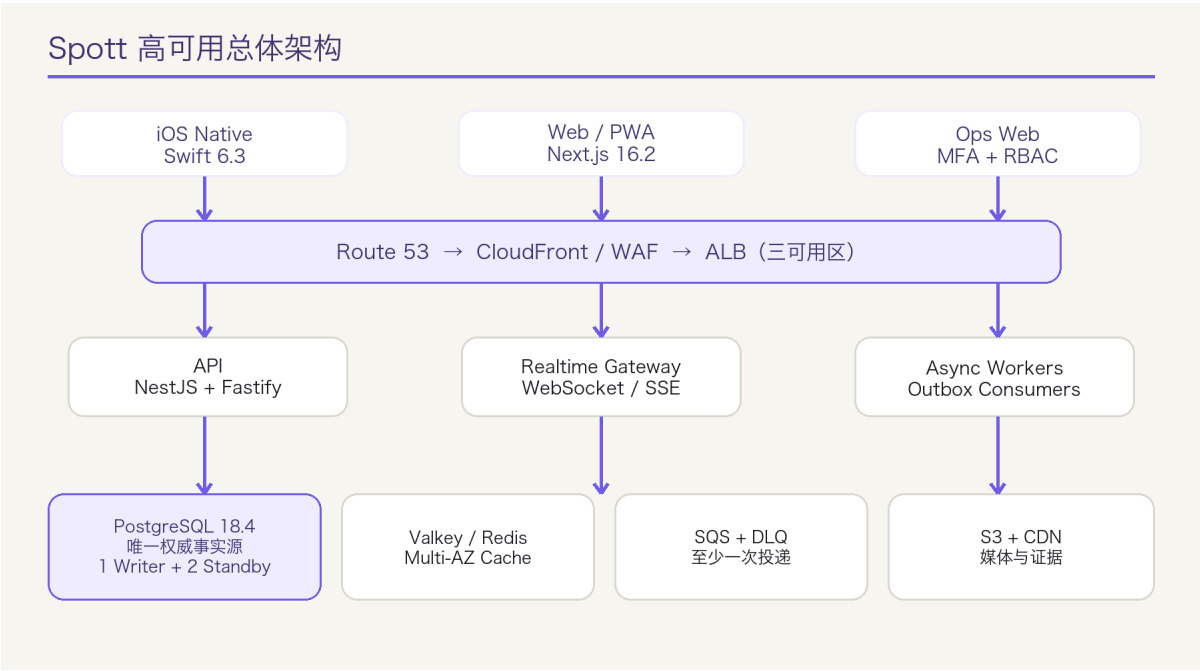


图 1 · Spott 高可用总体架构

5.2 逻辑组件

组件	职责	扩展策略
----	----	------

组件	职责	扩展策略
iOS App	原生体验、离线缓存、扫码、推送、StoreKit、日历/地图	App 模块化；关键链路独立 Feature Package
Web/PWA	公开发现、SEO、报名、局头工作台、用户中心	SSR/ISR 与应用区分层；边缘缓存公开内容
Ops Web	审核、配置、客服、审计、数据导出	独立域名/部署、MFA、短会话、严格 CSP
API	身份、权限、业务状态机、查询聚合、OpenAPI	水平扩展，无会话状态
Worker	通知、图片、审核、积分到期、报表、同步投递	按队列与任务类型独立扩容
PostgreSQL	权威业务数据、事务、约束、账本、审计、变更序列	Multi-AZ、读副本、PITR、分区与索引治理
Redis	限流、短期会话、分布式锁、WebSocket 路由、热点缓存	不保存不可恢复业务事实
Object Storage/CDN	图片、举报证据、导出、海报、静态资源	私有桶 + 签名 URL；公开衍生图走 CDN
Queue	Outbox 后续任务、通知、回调、重试与死信	至少一次投递，消费者幂等
Observability	日志、指标、Trace、错误、业务告警	全链路 <code>traceId</code> / <code>requestId</code>

5.3 推荐高可用部署拓扑

- 主区域：AWS 东京 `ap-northeast-1`；生产横跨三个可用区，公网入口为 Route 53 → CloudFront/WAF → ALB。
- API：ECS Fargate 或等价托管容器，三个可用区每区至少一个实例，最小 3 Tasks；按 RPS、CPU、内存和 p95 延迟自动扩到 30 Tasks。V1 不为“看起来先进”而先上 Kubernetes。
- Worker：通知、媒体、积分/订单、安全任务分队列；每类关键 Worker 最少跨两个可用区运行，支持按队列深度自动扩缩。
- 数据库：RDS for PostgreSQL 18 Multi-AZ DB Cluster，1 Writer + 2 Readable Standby 分布三可用区；RDS Proxy/PgBouncer 控制连接风暴；交易查询只走 Writer，报表和安全只读查询可走 Reader。

- 缓存：ElastiCache for Valkey/Redis compatible, Multi-AZ Primary + Replica, 自动故障切换、TLS、ACL, 不暴露公网；缓存丢失后系统仍可正确运行。
- 对象存储：S3 私有源桶 + CloudFront Origin Access Control；举报证据使用独立 KMS Key 和短时签名 URL；跨账号备份与版本控制。
- 队列：SQS 标准队列 + DLQ；至少一次投递，消费者幂等；顺序敏感业务按业务键串行化并再次校验版本。
- 邮件/短信/Push：供应商通过 Adapter 隔离；APNs 为 iOS Push，短信仅验证码和极少安全事件。OTP 预留主/备供应商切换。
- 部署：Web/API 蓝绿或金丝雀，健康检查、Connection Draining、自动回滚；数据库使用 Expand/Contract 实现零停机兼容迁移。

5.3.1 10 万用户初始容量建议

以下是采购与压测起点，不是未经压测的容量承诺：

资源	初始建议	扩容触发
API	3 × 1 vCPU/2GB Tasks, 自动扩到 30	CPU >60%、p95 >300ms、每 Task RPS 达基准 70%
Worker	关键队列各 2 Tasks	队列最老消息 >30s 或积压持续增长
PostgreSQL	1 Writer + 2 Reader；Graviton 内存优化型起步；200GB gp3/等价	CPU >60%、连接 >70%、IO/锁等待超预算
Connection Pool	API 每 Task 10-20；全局经 Proxy 限制	以事务吞吐和等待时间调优，不盲目加连接
Cache	Primary + Replica, 内存按热点数据 2 倍余量	Eviction >0、内存 >65%、热点延迟上升
CDN	所有公开图片/静态资源；公开详情短缓存	Origin 请求率或带宽异常
Queue	每类任务独立 Queue/DLQ	消费延迟、失败率、DLQ 任意增长

5.3.2 故障域与恢复顺序

单容器故障由编排器替换；单可用区故障由 ALB、Multi-AZ Database 与 Cache Failover 自动承接；数据库 Writer 切换期间关键写入返回可重试 503，客户端使用相同幂等键重试。恢复顺序为身份/只读浏览 → 报名/签到 → 积分/购买 → 后台高风险操作，避免在数据尚未验证时一次性开放全部写入。

5.4 模块边界

模块	拥有的核心聚合	可发布事件示例
Identity	User、Identity、Session、Device、PhoneVerification	<code>user.created</code> , <code>phone.verified</code> , <code>account.restricted</code>
Profile	Profile、Interest、Follow、Block	<code>profile.updated</code> , <code>follow.changed</code>
Event	Event、Media、Location、Question、RiskDeclaration	<code>event.submitted</code> , <code>event.published</code> , <code>event.changed</code>
Registration	Registration、Waitlist、Promotion	<code>registration.confirmed</code> , <code>waitlist.promoted</code>
Attendance	Checkin、DynamicCode、Correction	<code>attendance.checked_in</code> , <code>attendance.corrected</code>
Group	Group、Membership、Announcement、Role	<code>group.member_joined</code> , <code>group.capacity_changed</code>
Points	Wallet、LedgerEntry、Hold、StoreOrder、Refund	<code>points.posted</code> , <code>points.reversed</code> , <code>purchase.refunded</code>
Achievement	Definition、Progress、Award	<code>achievement.awarded</code> , <code>achievement.revoked</code>
Safety	Report、Evidence、ModerationCase、Appeal	<code>report.created</code> , <code>content.removed</code>
Notification	Notification、Preference、Delivery	<code>notification.created</code> , <code>delivery.failed</code>
Growth	ShareLink、Attribution、Campaign、Experiment	<code>share.opened</code> , <code>attribution.converted</code>
Admin	AdminUser、Role、Approval、Audit、Export	<code>admin.action_recorded</code>

5.5 架构决策记录（ADR）

ADR	决策	原因	代价
ADR-001	PostgreSQL 单一权威源	跨端一致、事务与审计能力强	需设计增量同步与缓存失效
ADR-002	模块化单体优先	V1 业务跨域事务多，降低分布式复杂度	需要严格模块依赖与所有权测试
ADR-003	REST + OpenAPI	易于离线、幂等、缓存、代码生成和审核	聚合查询需专门 Read Model
ADR-004	Outbox + Pull Sync	不把 WebSocket 当可靠日志，断线可追赶	增加变更表和清理策略
ADR-005	双分录积分账本	可对账、可冲正、不可静默改余额	写入路径更严格，运营不能直接改余额
ADR-006	iOS SwiftUI 主导	原生性能、系统能力、长期维护	复杂列表/相机需桥接 UIKit
ADR-007	公开页 SSR/ISR	SEO、分享落地与首屏性能	需处理缓存标签与隐私边界

6. Web 与 iOS 数据同步设计

6.1 同步目标

同步系统必须满足：多端同账号数据收敛、断网后可继续、重复操作不重复生效、关键并发不超卖/错账、敏感状态不从过期缓存泄露、服务端能追踪每个端最后看到和提交的版本。

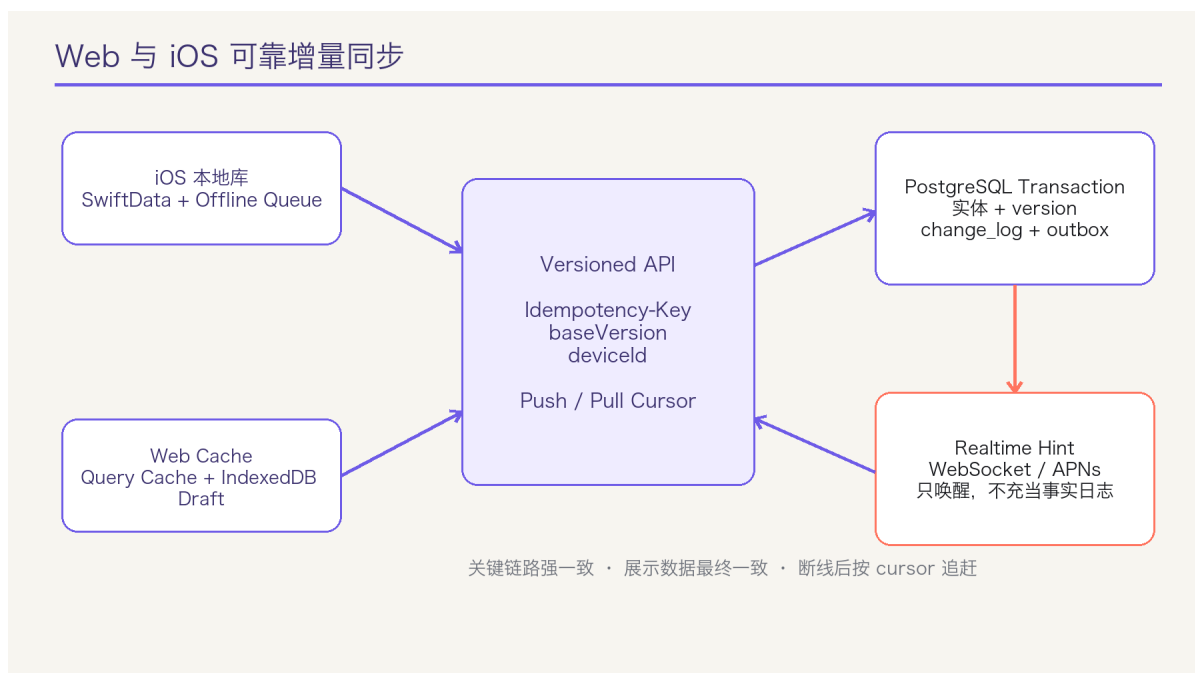


图 2 • Web 与 iOS 可靠增量同步

6.2 权威 ID 与版本字段

所有可同步实体使用服务端生成 UUIDv7；公开 URL 使用独立、可轮换的 `public_slug`，不得暴露自增主键。核心字段：

```

id uuid primary key,
version bigint not null default 1,
created_at timestamptz not null default now(),
updated_at timestamptz not null default now(),
deleted_at timestamptz null,
created_by uuid null,
updated_by uuid null

```

每次业务变更在同一 PostgreSQL 事务中更新实体、写审计信息、写 `change_log` 和 `outbox_events`。`version` 只递增不回退；软删除以 Tombstone 同步，客户端收到后清除可见数据并保留最小同步标记。

6.3 客户端同步状态

字段	说明
deviceId	App 安装/浏览器实例 ID；重装可重新生成，不作为用户身份
cursor	已成功应用的服务器全局变更序列
operationId	本地操作 UUID；同时作为写入幂等键
baseVersion	用户编辑开始时看到的实体版本
localState	clean、dirty、pushing、conflict、failed、tombstoned
lastSyncedAt	仅用于展示，不参与一致性判断
retryCount	指数退避与人工恢复提示

6.4 同步流程

1. 启动：读取本地数据库并立即渲染安全缓存；验证会话；调用 `/v1/sync/pull?cursor=...&limit=500`。
2. 应用：在本地单事务中按序应用 Upsert/Tombstone；只有全部成功才推进 `cursor`。
3. 推送：按创建依赖顺序提交离线操作；请求携带 `Idempotency-Key`、`operationId`、`baseVersion` 与 `deviceId`。
4. 实时：前台建立 WebSocket；消息只携带变更序列和主题，收到后触发增量 Pull，不把 WebSocket 消息本身当完整事实。
5. 后台：APNs 静默通知或 BGAppRefresh 仅负责唤醒；系统不保证执行时仍可在下次前台追赶。
6. 重连：以已提交 `cursor` 继续，允许服务端返回 `cursor_expired` 并要求从受控快照重新同步。

6.5 同步 API 示例

```
GET /v1/sync/pull?cursor=824018&limit=500
{
```

```

    "nextCursor": 824097,
    "hasMore": false,
    "serverTime": "2026-07-15T08:20:31.402Z",
    "changes": [
      {
        "seq": 824019,
        "entityType": "registration",
        "entityId": "019b...",
        "operation": "upsert",
        "version": 7,
        "changedFields": ["status", "confirmedAt"],
        "payload": {"status": "confirmed", "availableActions": ["cancel", "viewTicket"]}
      }
    ]
  }
}

POST /v1/sync/push
Idempotency-Key: 58f0d2c0-...
{
  "deviceId": "019a...",
  "operations": [
    {
      "operationId": "58f0...",
      "entityType": "profile",
      "entityId": "019b...",
      "action": "patch",
      "baseVersion": 12,
      "patch": {"bio": "东京周末徒步与城市摄影"}
    }
  ]
}

```

6.6 冲突解决矩阵

数据类型	策略	客户端行为
活动名额/报名	服务端事务裁决；不做 Last-Write-Wins	返回确认、待确认或满员；可引导候补
积分/订单	账本与幂等键裁决；不允许客户端合并	拉取权威余额与流水；失败操作不本地改账
签到	动态码、窗口、唯一约束和操作者权限裁决	显示权威结果；冲突进入补签/申诉
账号限制/审核	平台状态绝对优先	立即移除失效行动并清理敏感缓存
个人资料	字段级乐观锁；冲突返回 current/attempted	无冲突字段自动合并，冲突字段让用户选择
活动草稿	基于 baseVersion 的三方合并	显示云端更新时间、差异与恢复点
收藏/关注	集合语义；目标状态幂等	PUT 表示存在，DELETE 表示不存在
通知已读	单调合并	已读不能被旧端改回未读
评论/反馈	追加为主，编辑带版本	编辑冲突保留草稿并显示最新版本

6.7 强一致关键链路

报名事务必须在同一事务内：校验活动状态与截止时间 → 锁定活动容量行 → 查重有效报名 → 计算容量 → 创建报名/候补 → 创建积分预占或扣减 → 写变更与 Outbox → 提交。推荐使用 `SELECT ... FOR UPDATE` 锁定容量聚合行，并以数据库唯一索引作为最终防线。

积分事务必须在同一事务内：验证业务幂等键 → 锁定钱包 → 生成交易头 → 写至少两条平衡分录 → 更新可重建余额快照 → 写变更与 Outbox。任何冲正创建新交易，不更新或删除历史分录。

6.8 延迟与可见性目标

场景	目标	降级方式
同一用户 Web→iOS 前台	p95 3 秒内	WebSocket 失败时 30 秒短轮询 + 手动刷新
iOS 离线重连	30 秒内收敛	分页追赶；超过保留期重建快照
活动关键变更	事务后 5 秒内生成通知任务	队列积压告警；不可关闭通知仍保留站内记录
运营下架到公开不可见	p95 2 秒	CDN Tag Purge + API 权威校验
余额变化	写入响应立即返回权威余额	禁止仅依赖异步同步显示成功

6.9 缓存与失效

- 公开活动详情 CDN TTL 最长 60 秒，使用 Surrogate Key 按活动失效；取消、下架、关键变更必须主动 Purge。
- 登录态响应默认 `private, no-store` 或短期私有缓存；精确地址、举报、钱包、订单绝不进入共享缓存。
- Redis 缓存采用 Cache-Aside；Key 包含 schema/version；缓存删除失败不回滚主事务，但产生重试 Outbox。
- 客户端缓存记录 `visibilityScope`，退出登录、账号受限或用户切换时清理用户级与敏感级数据。

7. PostgreSQL 数据架构

7.1 数据库设计原则

- 使用业务约束、唯一索引、外键和检查约束防止非法状态，不把完整性只交给 ORM。
- 所有时间存 `timestamptz` UTC；日本自然日计算由服务端使用 `Asia/Tokyo` 明确转换。
- 金额使用整数日元 `bigint`；积分使用 `bigint`；经纬度使用 `PostGIS geography(Point,4326)`。
- 手机、邮箱存规范化密文与不可逆查重哈希；公开 ID 与登录标识分离。
- 运营删除默认为软删除；积分、订单、审核、审计与举报证据采用保留策略，不允许普通运营物理删除。
- schema 分域：`identity`、`community`、`events`、`commerce`、`safety`、`notification`、`growth`、`admin`、`sync`。

PostgreSQL 领域 Schema 与权威数据边界

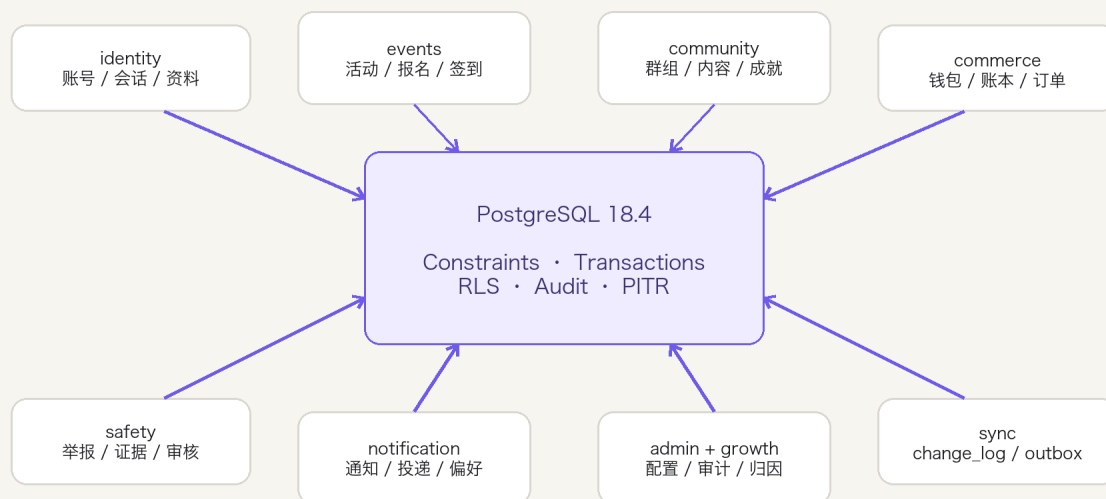


图 3 • PostgreSQL 领域数据边界

7.2 核心表目录

7.2.1 身份与资料

表	核心字段	关键约束
identity.users	id、public_handle、status、restriction_flags、phone_verified_at	handle 唯一；状态枚举检查
identity.auth_identities	user_id、provider、provider_subject、email_cipher	provider+subject 唯一
identity.phone_bindings	user_id、phone_hash、phone_cipher、verified_at、unbound_at	有效 phone_hash 部分唯一索引
identity.sessions	user_id、device_id、refresh_hash、expires_at、revoked_at	refresh 只存哈希，可单设备撤销
identity.devices	device_id、user_id、platform、push_token_cipher、risk_state	push token 加密；安装与用户解绑
identity.profiles	user_id、nickname、avatar_id、bio、region_id、birth_range、version	昵称/简介长度检查
identity.user_interests	user_id、tag_id、weight、source	user+tag 唯一
identity.follows	follower_id、target_type、target_id	三元组唯一；软删除可恢复
identity.blocks	blocker_id、blocked_id、reason_code	双方相同禁止；单向记录

7.2.2 活动、报名与签到

表	核心字段	关键约束
events.events	organizer_id、status、title、description、category_id、starts_at、ends_at、deadline_at、capacity、version	时间顺序、容量 2-500、状态检查
events.event_locations	event_id、region_id、public_area、exact_address_cipher、point、visibility	活动一对一；精确地址加密

表	核心字段	关键约束
events.event_media	event_id、asset_id、sort_order、focus_x、focus_y、moderation_state	sort 唯一，首图明确
events.event_fees	event_id、is_free、amount_jpy、collector_name、method、refund_policy	收费字段条件检查
events.event_risks	event_id、risk_type、declaration、review_state	event+risk 唯一
events.event_questions	event_id、type、label、required、options、sort_order	JSON schema 校验在服务层
events.event_capacity	event_id、confirmed_count、pending_count、waitlist_count	与报名状态事务维护
events.registrations	event_id、user_id、status、party_size、source、version	每用户每活动最多一条有效主记录
events.registration_answers	registration_id、question_id、answer_json	registration+question 唯一
events.waitlist_promotions	registration_id、offered_at、expires_at、accepted_at	同一时刻最多一个有效 offer
events.checkins	event_id、registration_id、user_id、method、checked_in_at、operator_id	registration 唯一签到
events.attendance_corrections	checkin_id、requested_by、reason、status、decided_by	全流程审计

7.2.3 群组与内容

表	核心字段	关键约束
community.groups	owner_id、name、slug、join_mode、capacity、status、version	capacity 50-500（大组织方案例外）
community.group_memberships	group_id、user_id、role、status、joined_at	group+user 唯一
community.group_admin_grant	group_id、user_id、granted_by、	有效授权唯一

表	核心字段	关键约束
s	revoked_at	
community.announcements	group_id、author_id、body、visibility、version	仅 owner/admin 可写
community.comments	target_type、target_id、author_id、body、status	受限目标类型；软删除
community.group_capacity_purchases	group_id、points_transaction_id、before_capacity、after_capacity	交易唯一；容量只增不减
community.group_transfers	group_id、from_user、to_user、state、cooldown_until	双方确认与 24h 冷静期

7.2.4 积分、订单与成就

表	核心字段	关键约束
commerce.wallets	user_id、paid_balance、free_balance、version	快照可重建，不能直接人工改
commerce.point_transactions	id、user_id、type、business_key、status、reversal_of	business_key 唯一；冲正关联原交易
commerce.point_entries	transaction_id、account_code、bucket、amount、expires_at	每交易分录代数数和为 0
commerce.point_holds	user_id、business_key、bucket_allocations、expires_at、state	预冻结唯一、超时释放
commerce.store_products	store、product_id、points、bonus_points、active_range	store+product 唯一
commerce.store_orders	user_id、store、original_transaction_id、signed_payload_hash、state	商店交易标识唯一
commerce.refunds	order_id、store_event_id、points_reversed、state	回调幂等
community.achievement_definitions	code、audience、rule_version、visibility	code+rule_version 唯一

表	核心字段	关键约束
community.achievement_awards	user_id、definition_id、awarded_at、revoked_at	有效 award 唯一

7.2.5 安全、通知、运营与同步

表	核心字段	关键约束
safety.reports	reporter_id、target_type、target_id、reason、severity、status	举报编号唯一，举报人不向被举报方暴露
safety.evidence_assets	report_id、asset_id、kms_key_ref、retention_until	私有访问与下载审计
safety.moderation_cases	report_id、assignee_id、sla_due_at、decision	处理状态机
safety.moderation_actions	case_id、action_type、subject_id、before_json、after_json	追加不可变
notification.notifications	user_id、type、payload_ref、created_at、read_at	read_at 单调更新
notification.deliveries	notification_id、channel、provider_id、state、attempts	channel+provider_id 去重
admin.feature_flags	key、scope、rules_json、version、starts_at、ends_at	变更审批和历史版本
admin.audit_logs	actor_id、action、resource、before_hash、after_hash、ip、trace_id	追加写、不可普通删除
sync.change_log	seq、user_scope、entity_type、entity_id、operation、version、payload	seq 全局递增，按用户/主题索引
sync.outbox_events	event_id、aggregate、type、payload、available_at、published_at	event_id 唯一；可重试
sync.idempotency_keys	key、user_id、request_hash、response_code、response_body、expires_at	key+user 唯一，请求哈希不一致拒绝

7.3 关键索引与约束

```
create unique index uq_active_registration
on events.registrations(event_id, user_id)
where status in ('pending', 'confirmed', 'waitlisted', 'checked_in');

create unique index uq_active_phone
on identity.phone_bindings(phone_hash)
where unbound_at is null;

create index ix_event_discovery_geo
on events.event_locations using gist(point);

create index ix_event_title_trgm
on events.events using gin(title gin_trgm_ops);

create index ix_change_log_user_seq
on sync.change_log(user_scope, seq);
```

积分平衡、状态迁移和容量计数除数据库约束外，还应配置每日一致性审计任务：账本分录总和、钱包快照、活动容量、报名状态和签到唯一性出现偏差时立即告警并冻结自动修复，先生成可审阅修复计划。

7.4 分区与保留

- `change_log`、`audit_logs`、`analytics_events`、`notification_deliveries` 按月范围分区。
- 在线同步变更至少保留 90 天；超过游标保留期的客户端使用快照重建。
- API 访问日志默认 30–90 天；安全与审计日志按合规审批保留更长时间。
- 举报证据和导出文件有独立保留到期任务；到期删除对象与元数据，并保留不可识别的删除证明。
- 软删除业务数据的匿名化、法定保留和物理删除策略由 Data Retention Policy 配置，不在代码中散落。

7.5 搜索与推荐数据

V1 搜索使用 PostgreSQL Full Text + `pg_trgm` + PostGIS：标题权重高于说明，标签与局头/群组名称形成独立字段；中文与日文分词效果不足的查询以 trigram、前缀和别名词典补齐。达到以下任一条件再引入 OpenSearch：可搜索活动超过 100 万、复杂聚合 p95 超过 500ms、跨语言召回不足、PostgreSQL 搜索负载影响交易库。

推荐服务先使用可解释打分：时间新鲜度、距离、兴趣匹配、关注关系、供给质量、名额可用性、探索因子与安全降权。任何商业置顶必须标记并设置自然结果最低占比；安全下架与账号限制在候选生成前过滤。

8. API 契约设计

8.1 通用约定

- Base URL: `https://api.spott.jp/v1`; 路径名词复数, 状态动作使用受控子资源。
- JSON 使用 camelCase; 数据库 snake_case 不直接泄露到客户端。
- 所有时间 RFC 3339 UTC, 同时可返回 `displayTimeZone: Asia/Tokyo`。
- 列表使用游标分页; 禁止暴露总页数依赖的深 Offset。
- 写请求携带 `Idempotency-Key`; 资源更新携带 `If-Match: "version" 或 baseVersion`。
- 成功响应包含 `requestId` 与必要的权威 `version`; 错误包含稳定 `code`、用户可读 `message`、字段错误和恢复行动。
- OpenAPI 在 CI 中生成 Swift Client 与 TypeScript 类型; 生成层不得包含 UI 和业务状态机。

8.2 身份与账号 API

Method	Path	用途	关键要求
POST	<code>/auth/apple</code>	Apple 登录	校验 identity token、nonce、防重放
POST	<code>/auth/google</code>	Google 登录	服务端校验 token audience/issuer
POST	<code>/auth/email/challenges</code>	发送邮箱验证码	IP/设备/邮箱限流
POST	<code>/auth/email/verify</code>	验证并登录	一次性 challenge, 旋转会话
POST	<code>/auth/refresh</code>	刷新访问令牌	refresh rotation, 重用检测
DELETE	<code>/sessions/{id}</code>	退出指定设备	当前/全部设备可撤销
POST	<code>/phone/challenges</code>	发送 +81 验证码	频率、风险、号码格式、隐私日志
POST	<code>/phone/challenges/{id}/verify</code>	验证手机号	5 次错误、30 分钟暂停、奖励幂等
POST	<code>/accounts/merge/preview</code>	账号合并预览	返回冲突、数据归属与不可逆影响
POST	<code>/accounts/merge/commit</code>	提交合并	二次验证、审计、幂等

Method	Path	用途	关键要求
POST	/accounts/deletion-request	发起注销	前置检查与 14 天冷静期

8.3 发现、活动与报名 API

Method	Path	用途	一致性/缓存
GET	/discovery/feed	个性化发现	私有短缓存，游标分页
GET	/events/search	组合搜索/地图	公开短缓存；返回查询解释 ID
GET	/events/{id}	活动详情	公共/登录态视图分离；条件缓存
PUT	/events/{id}/favorite	收藏	目标状态幂等
DELETE	/events/{id}/favorite	取消收藏	目标状态幂等
POST	/events/drafts	创建草稿	离线操作可重放
PATCH	/events/{id}	更新草稿/活动	乐观锁；关键变更触发通知
POST	/events/{id}/submit	提交审核	手机验证、积分预冻结、风险路由
POST	/events/{id}/cancel	取消活动	原因、通知、积分处理、审计
POST	/events/{id}/registrations	报名/申请	强一致、幂等、防超卖
POST	/registrations/{id}/waitlist-acceptance	接受递补	截止时间与唯一 offer
POST	/registrations/{id}/cancel	取消报名	返回权威退分结果
GET	/me/registrations	我的活动	登录态游标列表

8.4 群组、积分、安全与后台 API

Method	Path	用途	关键要求
POST	/groups	创建群组	手机验证、积分、容量、审核
POST	/groups/{id}/join	加入/申请	容量与拉黑检查
PATCH	/groups/{id}/members/{userId}	角色/禁言/移除	权限矩阵、审计

Method	Path	用途	关键要求
POST	/groups/{id}/capacity-purchases	积分扩容	账本事务与幂等
GET	/wallet	双余额与到期	no-store, 权威响应
GET	/wallet/transactions	流水	游标分页, 不泄露内部账户
POST	/store/apple/transactions	验证 StoreKit 交易	签名校验、订单幂等
POST	/webhooks/apple/storekit	商店服务器通知	V2、TLS、签名、重试去重
POST	/reports	举报	证据上传票据、匿名保护
POST	/appeals	申诉	关联处理决定与补充材料
GET	/ops/moderation/cases	审核队列	MFA、RBAC、字段级脱敏
POST	/ops/moderation/cases/{id}/decision	处理决定	版本锁、二次确认、完整审计
POST	/ops/config-revisions/{id}/approve	配置审批	提交人与审批人分离

8.5 错误模型

```
{
  "error": {
    "code": "REGISTRATION_CAPACITY_FULL",
    "message": "活动名额刚刚报满，可以加入候补。",
    "requestId": "req_019b...",
    "retryable": false,
    "fieldErrors": [],
    "actions": [{"type": "joinWaitlist", "label": "加入候补"}],
    "meta": {"waitlistEnabled": true}
  }
}
```

HTTP	使用	示例代码
400	格式或字段非法	VALIDATION_FAILED
401	未登录/令牌失效	AUTH_REQUIRED, TOKEN_EXPIRED
403	无权限或账号受限	PHONE_VERIFICATION_REQUIRED, ACCOUNT_RESTRICTED
404	不存在或对当前用户不可见	EVENT_NOT_FOUND

HTTP	使用	示例代码
409	业务冲突/版本冲突	VERSION_CONFLICT, CAPACITY_FULL
422	状态不允许	INVALID_STATE_TRANSITION
429	限流	OTP_RATE_LIMITED
503	依赖不可用/临时降级	SERVICE_TEMPORARILY_UNAVAILABLE

8.6 API 安全与限流

- Access Token 10–15 分钟，Refresh Token 旋转并绑定 device session；iOS Refresh Token 只存 Keychain。
- 公共读取按 IP/ASN/设备指纹限流；短信、登录、报名、积分、举报分别设置业务限流桶。
- 后台 API 使用短会话 + MFA + 设备校验；敏感导出要求重新认证与用途说明。
- 上传先申请受限 Presigned URL，完成后服务端验证 MIME、尺寸、哈希、病毒与内容审核，再绑定业务资源。
- Web 使用 HttpOnly、Secure、SameSite Cookie，CSRF Token 与严格 CSP；禁止将访问令牌放在 LocalStorage。

9. iOS 原生开发规范

9.1 技术基线

项目	选择
语言	Swift 6 语言模式，开启严格并发检查
UI	SwiftUI 主导；扫码、富文本编辑、性能敏感列表可封装 UIKit
最低系统	iOS 17.0；发布前根据日本目标设备分布复核
架构	Feature-first + Clean boundaries；MVVM/Reducer 均可，但单向数据流必须统一
并发	async/await、Actor、AsyncSequence；禁止新代码使用回调地狱
网络	URLSession + 生成的 OpenAPI Client + 自定义 Auth/Retry/Trace Middleware
本地数据	SwiftData 持久缓存；敏感令牌 Keychain；轻量偏好 AppStorage
图片	AsyncImagePipeline（自研薄封装或审计后的库），内存/磁盘分级缓存
依赖管理	Swift Package Manager；依赖锁定版本并生成 SBOM
测试	Swift Testing/XCTest、XCUITest、Snapshot、Network Stub

9.2 工程结构

SpottApp/	
App/	# App entry、路由、依赖组装、生命周期
DesignSystem/	# Tokens、Typography、Components、Motion、A11y
Core/	
API/	# OpenAPI 生成层、Auth、Retry、Error Mapping
Persistence/	# SwiftData 模型、Migration、Repositories
Sync/	# SyncEngine、OperationQueue、Cursor、Conflict
Security/	# Keychain、App Attest、敏感缓存策略
Analytics/	# 事件协议、Consent、Trace correlation
Features/	
Discovery/	
EventDetail/	
Registration/	
EventComposer/	

```

HostStudio/
Groups/
Wallet/
Notifications/
Safety/
Profile/
Integrations/      # StoreKit、APNs、MapKit、EventKit、Photos、ActivityKit
Resources/         # Localizable、Assets、PrivacyInfo
Tests/

```

每个 Feature 暴露 `FeatureView`、`FeatureModel`、`FeatureRoute` 与依赖协议，不直接访问全局 Singleton。跨 Feature 导航通过 Typed Route，业务副作用通过 Use Case/Repository；View 不直接拼接网络请求。

9.3 状态管理

- ViewState 必须区分 `initial/loading/content/empty/error/offlineContent`，不使用一个 `isLoading` 覆盖所有阶段。
- FeatureModel 标记 `@MainActor`；网络、图片、同步和解析在独立 Actor 中执行。
- 用户操作先生成 `operationId`。允许 Optimistic UI 的操作必须有明确回滚和服务端确认状态。
- 服务端返回的 `availableActions` 映射为 UI 行动；本地时钟只用于倒计时展示，截止判断以服务端结果为准。
- Deep Link 路由先解析公开对象，再根据登录/手机验证/权限逐步 Gate，成功后返回原目标。

9.4 SyncEngine 设计

```

actor SyncEngine {
    func bootstrap(userID: UserID) async throws
    func pull(reason: SyncReason) async throws -> SyncResult
    func enqueue(_ operation: PendingOperation) async throws
    func flushPendingOperations() async -> FlushResult
    func handleRealtimeHint(sequence: Int64) async
    func resetSensitiveScope(reason: ResetReason) async throws
}

```

- 同一用户只允许一个 Pull 和一个有序 Push 流程；Pull 可与图片加载并行，但不能并行推进 cursor。
- 本地应用变更和 cursor 更新使用同一 SwiftData transaction；应用中断不得留下“游标已前进、数据未落地”。
- Operation Queue 按依赖拓扑排序；新建草稿成功后将本地临时 ID 映射为服务器 UUID，并原子重写依赖操作。

- 4xx 业务错误进入可解释失败；401 尝试一次刷新令牌；429/5xx 使用带抖动指数退避；幂等请求才自动重试。
- 前台 WebSocket 收到 `sequence` 只触发 Pull；不直接将消息 Payload 写入本地业务表。

9.5 系统能力集成

能力	Framework	实现要求
Apple 登录	AuthenticationServices	nonce、防重放、账号状态变化处理
推送	UserNotifications/APNs	Token 轮换、分类行动、隐私预览、Deep Link
地图与路线	MapKit	用户可选定位；精确地址权限检查；路线交给 Maps
日历	EventKit	报名成功后用户主动添加；不默认批量读取日历
扫码	AVFoundation/VisionKit	权限前置说明、手电筒、弱光、重复帧去抖
动态岛/锁屏	ActivityKit	活动前 1 小时可选开启；取消/下架立即结束
内购	StoreKit 2	服务端验签、交易监听、恢复、退款与回调对账
图片	PhotosUI	Limited Library 支持；上传前预览与裁切焦点
后台任务	BackgroundTasks	仅作为同步增强，不依赖确定执行时间
设备可信	App Attest/DeviceCheck	高风险动作分级使用，不阻断所有正常用户

9.6 StoreKit 与积分

- iOS 购买付费积分使用 Consumable IAP；商品 ID 与服务端商品表映射。
- 客户端完成交易后把签名交易提交服务端；只有服务端验证并成功记账后显示权威余额。
- App 启动持续监听未完成交易；同一 `originalTransactionId/transactionId` 由数据库唯一约束防重复发放。
- App Store Server Notifications 使用 V2；退款、撤销与拒付生成冲正交易，余额不足进入负付费积分限制。
- 已购买的跨平台数字权益可以在同一账号使用；Web 购买入口、价格差异和 iOS 内引导必须在发布前按日本区最新 App Review 规则单独审批。

- 付费积分不得过期；免费积分按批次到期，消费顺序由服务端返回，不由客户端自行扣桶。

9.7 推送与 Live Activity

- 通知 Payload 只含通知 ID、类型、资源公开 ID 与路由，不含完整手机号、精确投诉内容或地址。
- 关键变更/取消通知点击后先 Pull 最新状态，再展示详情，避免过期 Push 进入旧页面。
- Live Activity 展示倒计时、城市/集合范围、路线与票码入口；锁屏不默认显示精确地址，可由用户设置。
- 活动取消、账号限制或票码轮换后服务端发送结束/更新；客户端本地超时作为兜底。

9.8 iOS 质量门槛

- SwiftLint/SwiftFormat 规则在 CI 固定；主分支警告视为失败。
- 严格并发检查无数据竞争警告；主线程网络/图片解码为失败。
- 所有核心页面支持 Dynamic Type 到辅助功能字号，不截断关键按钮与费用说明。
- VoiceOver 顺序、标签、状态、可操作提示完整；颜色不是唯一状态编码。
- Instruments 检查冷启动、列表滚动、图片峰值、内存泄漏、Energy 与后台唤醒。
- 崩溃率目标大于 99.8% crash-free sessions；关键报名/积分错误单独作为业务 SLI。

10. Web 与运营后台开发规范

10.1 Web 技术基线

项目	选择
Framework	Next.js（稳定 LTS/当前稳定大版本）+ React + TypeScript strict
Rendering	公开页 SSR/ISR；登录态页面 Server Components + Client Islands
Styling	CSS Variables + CSS Modules/Tailwind 二选一落地；语义 Design Tokens 为唯一真相
Data	生成的 OpenAPI SDK；服务端请求与浏览器请求共享错误模型
Form	Schema 驱动校验；客户端即时反馈，服务端最终校验
Cache	CDN Tag Cache、浏览器 Query Cache、IndexedDB 草稿
Testing	Vitest、Testing Library、Playwright、Axe、Visual Regression
Observability	Web Vitals、RUM、Source Map、Trace Context

10.2 Web 分层

apps/	
web/	# 公开站与用户/局头应用
ops/	# 运营后台，独立安全边界
packages/	
design-tokens/	# iOS/Web 共享语义令牌源
ui/	# Web 组件库
api-client/	# OpenAPI 生成类型与调用层
domain/	# 纯 TypeScript 枚举/格式化/错误映射
analytics/	# 埋点 Schema 与 Consent

公开站和 Ops 不共享认证 Cookie、CSP 或部署域名。公共 UI 组件可以共享，但后台不得因为组件复用而引入面向用户的脚本或第三方分析。

10.3 SSR、SEO 与分享落地

- 公开活动页服务器渲染标题、摘要、封面、时间、城市、局头与状态；精确地址按登录权限二次请求。
- 使用 canonical、Open Graph、Twitter Card、JSON-LD Event；取消活动保留页面并明确状态，长期下架返回受控 410/404 策略。
- 分享参数先记录匿名点击再跳转到规范 URL；公开 URL 不出现用户手机号、邮箱、内部数据库 ID 或可逆个人标识。
- Universal Link 使用 <https://spott.jp/e/{slug}>；未安装 App 时保留完整 Web 功能，不能强制跳商店。
- CDN 缓存按活动 Tag 主动失效；页面状态仍在关键操作前由 API 再验证。

10.4 响应式体验

- 360–767px：单列移动布局，底部关键行动固定但不遮挡内容。
- 768–1199px：双列详情，封面与行动卡分离；筛选侧边面板。
- 1200px 以上：发现页最大宽度 1280px；局头工作台使用高密度表格与批量操作。
- 不把桌面表格直接压缩为移动横向滚动；在移动端转换为卡片/定义列表。
- Pointer、Keyboard、Touch 均可完成核心流程；Focus Ring 不得被视觉样式移除。

10.5 局头工作台

- 概览：未来活动、待审核报名、候补、需处理变更、到场与复购摘要。
- 活动管理：保存视图、状态筛选、名单、候补、签到、公告、复制、取消；敏感导出单独权限。
- 草稿编辑：桌面左右双栏，左侧字段、右侧实时预览；每次保存显示云端版本与最后同步时间。
- 报名名单：默认不展示手机号；仅显示履约所需昵称、报名问题和状态；敏感字段按需揭示并记审计。
- 数据复盘：展示浏览→报名→签到→复购漏斗，不提供可识别的个人行为导出。

10.6 运营后台安全设计

- 独立域名、强制 MFA、短会话、无长期 Refresh Token；高风险动作重新认证。

- RBAC + 数据范围：客服、审核、积分审批、财务只读、安全负责人、超级管理员分离。
- 列表默认脱敏；查看完整手机号、地址、证据需明确业务理由并写审计。
- 积分人工调整使用“申请→审批→执行”三段式；申请人与审批人不能相同。
- 配置修改以 Revision 发布：草稿、自动校验、预览影响、审批、定时生效、回滚；历史不可改写。
- 导出文件加水印、短期有效、下载次数限制；生成和每次下载均记录。

10.7 PWA 边界

PWA 提供安装提示、离线壳、公开缓存、草稿恢复和基础通知（浏览器支持时），但不承诺与 iOS 原生相同的后台同步、扫码性能、Live Activity、StoreKit 或系统整合。PWA 缓存策略必须对敏感响应使用 Network Only，Service Worker 更新失败不得让用户长期停留在旧业务规则。

11. 后端模块详细设计

11.1 身份、登录与账号合并

- Apple/Google/邮箱身份均映射到 `users`，外部 Subject 只作为登录凭证。
- 手机号规范化为 E.164 +81...，明文加密存储，查重使用带 Pepper 的 HMAC；日志仅显示尾号。
- OTP 6 位、10 分钟有效；错误 5 次暂停 30 分钟；手机号、IP、设备、ASN 多维限流可配置。
- 账号合并先生成 Preview：身份冲突、手机号、积分、活动/群组所有权、拉黑关系、通知设置；Commit 使用串行事务与合并审计。
- 注销进入 14 天冷静期；存在未结束活动、群主未转让、投诉或负积分时进入明确待处理状态。

11.2 活动发布与审核

- 活动是聚合根，媒体、地点、收费、风险、问题均随主版本校验；草稿允许不完整，提交必须完整。
- 风险引擎输出命中规则、分数、解释和建议路线：自动通过、抽样、人工审核、禁止。
- 提交时预冻结发布积分；通过后 Capture，拒绝或审核前撤回 Release。
- 关键字段（时间、地点、费用、收款、条件）变更创建 `event_revision` 与影响摘要，通知所有报名/候补用户，并根据规则要求重新确认。
- 取消/下架停止新报名与分享，写入积分退回任务、通知 Outbox 和 CDN Purge；未完成副作用在后台可追踪重试。

11.3 报名、候补与签到

报名状态由服务器执行，客户端不允许直接 PATCH status。容量以 confirmed/pending 的产品规则决定占位；审核制若 Pending 占位，拒绝时释放并触发候补；若不占位，则确认时再次抢占，产品必须在实现前选定并记录 ADR。V1 推荐 Pending 暂占 15 分钟或直到局头处理 SLA，以减少超额确认。

候补按 `waitlist_joined_at`，`id` 稳定排序。自动递补创建唯一 Offer 和截止时间；过期任务使用数据库时间与条件更新，重复 Worker 不重复推进。局头人工递补仍不得绕过顺序，特殊跳过必须记录原因并向运营可见。

签到动态码每 30 秒轮换，服务端验证事件、时间窗、签名和一次性登记；二维码只携带短期 Token，不携带用户手机号或长期身份。弱网手动签到进入本地待同步名单，局头端显示“待服务器确认”，服务端根据操作时间、活动权限和重复记录裁决。

11.4 群组

- 群组初始容量 50；扩容通过积分事务成功后写容量，不允许先扩容后扣分。
- 加入操作锁定群组容量并查重；达到容量返回可解释错误，现有成员不受影响。
- 角色权限通过统一 Policy Engine 判定；Owner 转让后原 Owner 降级为 Member 或指定角色。
- 转让要求目标成员手机已验证且入群满 7 天；双方确认后进入 24 小时冷静期，到期 Worker 原子交换所有权。
- 有未结束活动时不可解散；解散提前 7 天通知，导出不含成员手机号。

11.5 积分与内购

积分使用双桶双分录：paid 与 free。消费分配顺序为即将到期免费 → 其他免费 → 付费；每笔消费保存实际桶分配，冲正按原分配返回并遵循到期补偿规则。用户界面的总积分只是两个权威余额的和，不是独立账本。

业务	交易模式	幂等业务键示例
手机验证奖励	Credit free	phone_verified:{bindingId}
报名消费	Debit allocated buckets	registration_fee:{registrationId}
发布预冻结	Hold	event_publish_hold:{submissionId}
审核通过	Capture hold	原 Hold key 派生
活动取消退回	Reversal	event_cancel_refund:{registrationId}:{revision}
iOS 内购	Credit paid + bonus free	apple_tx:{transactionId}
商店退款	Reverse paid/bonus	apple_refund:{notificationUUID}
运营补偿	Credit free/paid by policy	admin_adjustment:{approvalId}

免费积分批次记录 `expires_at`，到期任务以追加过期交易扣除，不直接改余额。人工调整进入审批系统后调用与普通业务相同账本 API。每日执行试算平衡与商店订单对账；任何差异生成 Case 而非静默修复。

11.6 通知与消息投递

- 业务模块只创建语义通知，不直接调用 APNs/邮件供应商。
- Notification Orchestrator 根据类型、用户偏好、静默时段、不可关闭规则和频控生成 Delivery。
- 关键取消/安全通知绕过普通静默，但仍避免同一事件重复推送；站内通知始终保留。
- 模板版本化并本地化；Payload 只存模板变量，渲染结果与模板版本可追溯。
- 供应商超时使用指数退避；永久错误停用无效 Token；重试上限后进入 DLQ 和运营告警。

11.7 内容安全与客服

- 举报对象使用多态 Reference，但服务层限制允许类型；提交后生成不可猜测工单号。
- 风险分级：P0 人身/未成年人/诈骗紧急、P1 高风险、P2 普通内容；SLA 后台配置。
- 处理动作可组合：隐藏内容、限制发布/报名/积分/评论、冻结、证据保全、通知、申诉入口。
- 紧急动作允许先处置后复核；所有动作记录执行人、依据、前后状态、范围、期限和关联证据。
- 被举报方永不获得举报人身份；客服界面按案件需要最小展示。

12. 核心状态机与业务规则

12.1 活动状态机

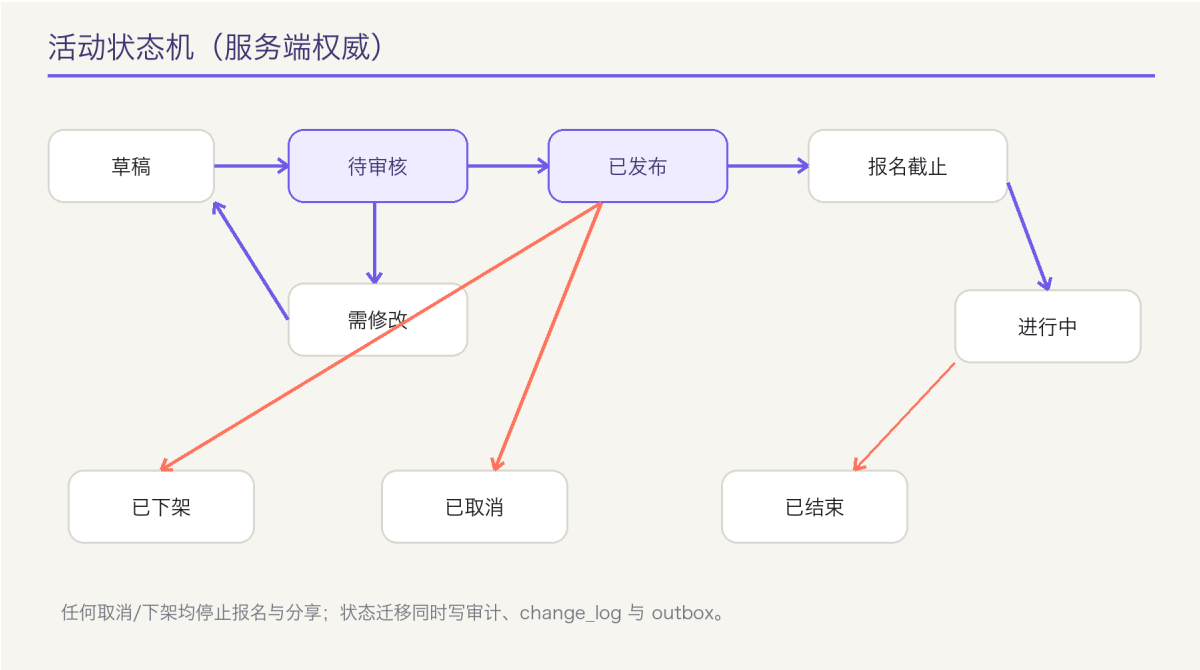


图 4 · 活动状态机

当前状态	允许进入	主要守卫条件
draft	pending_review、deleted	字段可不完整；删除仅无外部影响
pending_review	needs_changes、published、rejected、draft	审核中关键字段不可改；撤回释放积分 Hold
needs_changes	pending_review、draft、deleted	必须针对原因修改
published	registration_closed、in_progress、cancelled、removed	关键修改创建 Revision 与通知
registration_closed	in_progress、cancelled、removed	禁止新增报名，准备签到
in_progress	ended、cancelled、removed	允许签到与紧急取消
ended	archived、removed	补签、反馈、复盘、复制

当前状态	允许进入	主要守卫条件
cancelled	archived	不恢复为 published；重新活动需复制
removed	appeal_pending、archived	不公开、不报名；证据保留

12.2 报名状态机

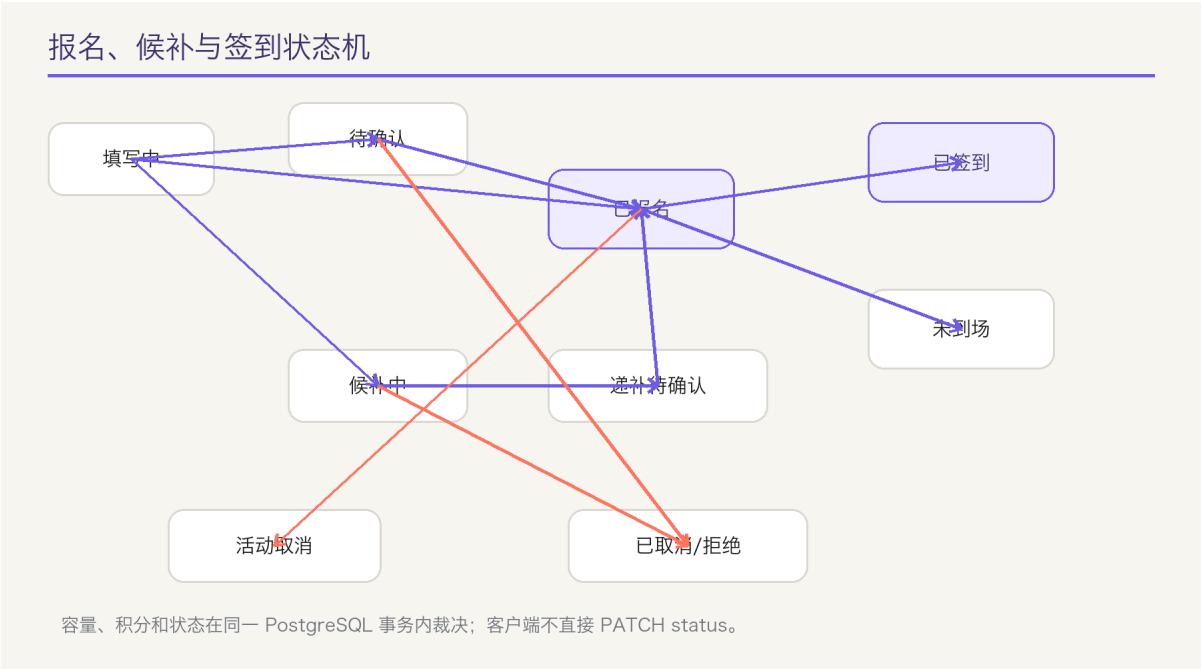


图 5 · 报名与签到状态机

当前状态	允许进入	积分/容量影响
filling	pending、confirmed、waitlisted	未提交不扣分不占位
pending	confirmed、rejected、cancelled	按 ADR 暂占；积分可 Hold
confirmed	checked_in、cancelled、no_show、event_cancelled	占用容量；积分已 Capture
waitlisted	offered、cancelled、event_cancelled	不占正式容量
offered	confirmed、waitlisted、expired、cancelled	预留短期名额；到期顺延
checked_in	attendance_disputed	发到场奖励，允许评价

当前状态	允许进入	积分/容量影响
no_show	correction_pending、checked_in	默认不发奖励；可补签
event_cancelled	final	退回报名积分

12.3 账号限制优先级

权限判定顺序：平台全局安全策略 → 账号登录状态 → 组合 restriction flags → 基础角色 → 活动/群组内角色 → 对象状态 → 积分/额度。restriction flags 至少包括 loginBlocked、publishBlocked、registerBlocked、pointsBlocked、commentBlocked；不得为处理单一问题默认永久封禁所有能力。

12.4 配置生效规则

- 配置对象：积分获取/消耗、有效期、上限、免费额度、地区、分类、审核阈值、活动风险、通知时点、签到窗口、推荐权重。
- 每个配置 Revision 有 effectiveFrom/effectiveTo/audience/region/appVersion。
- 一笔业务在确认页生成 Quote，提交时携带 quoteId；服务端在 Quote 有效期内按确认价格执行，配置中途变化不追溯已确认交易。
- 回滚创建新 Revision，不改写历史；客户端读取配置失败时使用最近已验证配置并限制高风险新交易。

13. 安全、隐私与合规工程

13.1 数据分级

等级	示例	控制
Public	公开活动标题、封面、城市、公开主页	CDN 可缓存，仍需内容审核与完整性保护
Internal	推荐权重、运营配置、聚合指标	员工最小权限，不进入公开日志
Confidential	邮箱、手机号、精确地址、生日段、设备风险	加密、字段脱敏、访问审计、禁止共享缓存
Restricted	举报证据、未成年人材料、付费积分账本、商店签名、后台高权凭证	独立 KMS Key、严格 RBAC、短时访问、双人审批/保留策略

13.2 加密与密钥

- 传输 TLS 1.2+，优先 TLS 1.3；内部服务也启用 TLS。
- RDS、S3、备份、日志存储使用 KMS 加密；Restricted 数据使用独立密钥与访问策略。
- 手机、精确地址、Push Token 等字段在应用层信封加密；查重使用 HMAC，禁止普通 SHA 哈希手机号。
- 密钥不进入代码、镜像、CI 日志或客户端；使用 Secrets Manager，定期轮换并支持双版本解密迁移。
- iOS Keychain 使用 ThisDeviceOnly 等适当访问级别；截屏/后台快照对票码、余额和证据页面做隐私遮罩。

13.3 身份与授权

- API 授权采用 Policy，而非散落的 `isAdmin` 判断；Policy 输入用户、角色、restriction、对象关系、状态和动作。
- PostgreSQL RLS 可作为运营/多租户敏感表的纵深防御，但不替代服务层授权；服务账号按模块授予最小权限。
- 后台高权角色使用硬件/平台 Passkey 或 TOTP MFA；恢复流程需要人工审批和审计。

- 账号登录异常、Refresh 重用、设备风险升高时撤销相关会话并要求重新验证。

13.4 Web 与 API 防护

- 防护 OWASP Top 10：参数化 SQL、输出编码、CSRF、CSP、上传验证、SSRF 出站白名单、依赖扫描。
- Graph/REST 资源查询设最大深度、分页上限、字段大小和超时；富文本清洗后存储与渲染。
- 登录、OTP、报名、举报和分享归因防自动化；使用速率、设备关联、行为信号和必要时挑战。
- 管理后台禁止第三方广告脚本；公共分析在同意策略下加载，不采集验证码、完整手机号、投诉正文。
- 安全响应头：HSTS、CSP、X-Content-Type-Options、Referrer-Policy、Permissions-Policy。

13.5 日本隐私与应用商店检查点

- 以日本个人信息保护委员会发布的 APPI 与最新通则指南为合规基线，建立数据清单、处理目的、保存期限、第三方/境外提供与用户请求流程。
- App Privacy、Privacy Manifest、SDK 数据实践必须与实际代码和供应商一致；第三方 SDK 上线前完成数据与网络审计。
- 数字功能积分的 iOS 购买使用 StoreKit；付费积分不得过期并提供恢复/对账路径。跨平台购买与外链提示按日本区上线时最新 App Review Guidelines 复核。
- 线下活动费属于平台外组织者自收边界；产品文案、客服脚本、数据库与支付链路均不得产生平台代收或担保的事实。
- 上线前由日本专业人士复核：付费积分法律/会计分类、退款/拒付、隐私、未成年人、活动责任、特定商业交易与通信相关义务。

13.6 隐私权利与注销

- 用户可导出公开资料、报名/活动记录、群组、积分流水与设置；他人隐私、举报证据和安全内部信息不导出。
- 更正与删除请求进入工单状态机；法律/安全需保留的数据从产品可见面移除并限制用途。
- 注销冷静期内登录可撤销；到期任务匿名化公开内容归属、撤销会话、移除营销、处理群主转让并保留必要审计。

- Spott 与 Stareal 逻辑分区；只有用户明确选择接收相关服务信息时才建立营销用途关联，默认不共享。

13.7 安全事件响应

等级	示例	首要行动
SEV-0	活跃数据泄露、积分账本大规模错误、后台被接管	立即封锁、保全证据、负责人升级、对外响应流程
SEV-1	报名超卖、敏感地址越权、退款重复扣回	停止相关写入、启用降级、修复与用户补偿
SEV-2	Push 延迟、推荐错误、单功能高错误率	降级/回滚、创建事件、24h 内复盘计划
SEV-3	非关键 UI/统计问题	正常缺陷流程

每次 SEV-0/1 必须有时间线、影响范围、根因、检测缺口、修复、预防与验证；复盘不以追责个人为目的，但行动项必须有 Owner 和期限。

14. 非功能要求与 SLO

14.1 性能预算

指标	目标	测量位置
API GET p95	< 300ms	服务端入口到响应，不含客户端网络
API 关键 POST p95	< 500ms	报名/积分/签到，第三方依赖另计
公开 Web LCP p75	< 2.5s	日本真实用户 RUM
Web INP p75	< 200ms	真实用户
iOS 冷启动可交互	< 1.8s	主流近三年设备，缓存可用
iOS 列表滚动	55-60fps	Instruments，标准卡片密度
首次增量同步	500 变更 < 2s	Wi-Fi/5G 基准环境
图片上传	进度可见，可续传	10MB 原图，弱网测试

14.2 可用性与恢复

- P0 API 月可用性 99.95%；公开只读页 99.95%；运营报表 99.5%。
- RPO 目标 5 分钟，RTO 目标 60 分钟；积分/订单恢复后执行外部商店与内部账本对账。
- PostgreSQL 开启 PITR 与自动备份；每季度在隔离环境执行恢复演练并记录真实 RPO/RTO。
- 单可用区故障自动切换；整区域灾难初期采用经过演练的备份恢复，达到规模后再建设跨区域热备。
- Redis/Queue 故障不得造成交易事实丢失；Outbox 恢复后可重放。

14.3 可扩展性与 10 万用户容量模型

设计基线按 10 万注册用户、3 万 MAU、2 万峰值 DAU、5,000 同时在线、日均 300 万 API 请求、突发 1,000 RPS、每日 5,000 个可报名活动、单活动 500 并发报名规划。公开静态与图片流量优先由 CDN 承担，API 无状态水平扩展，大列表使用游标，所有连接通过池化，热点活动容量行单独压测锁竞争。

工作负载	基线	验证目标
普通 API	稳态 150~300 RPS，突发 1,000 RPS	2 倍预估峰值下不雪崩，限流可解释
WebSocket	5,000 同时在线	连接重建不触发全量同步风暴
活动发现	每日千万级曝光事件	埋点异步，不拖慢业务请求
热点报名	单活动 500 并发、最后 1 个名额	不超卖、不重复有效报名、不重复扣分
同步追赶	单设备最多 10,000 变更	分页、可续跑、游标正确，内存不爆
通知峰值	活动取消 10 万用户级扇出	Outbox/Queue 分批，站内记录优先，供应商限速
钱包	每日 10 万账本交易	分账平衡、快照一致、对账在窗口内完成

压测必须使用接近生产的数据分布、索引、连接池和网络拓扑。通过条件不仅是平均延迟，还包括 p95/p99、错误率、锁等待、数据库 CPU/IO、队列延迟、内存、自动扩容时间和故障后的恢复时间。达到峰值 2 倍时仍不得破坏报名、积分和签到不变量。

14.4 无障碍与国际化

- iOS 支持 VoiceOver、Dynamic Type、Increase Contrast、Reduce Motion、Button Shapes 与足够触控尺寸。
- Web 遵循 WCAG 2.2 AA：键盘、Focus、语义区域、表单错误关联、对比度、直播区域节制。
- 本地化 Key 使用语义名称；不拼接句子；日期、数字、货币、复数和地址格式使用 Locale API。
- 数据层分离 `title_default` 与翻译表；用户生成内容标注源语言，不自动覆盖原文。
- 日本时区只用于展示与自然日规则，数据库仍存 UTC；夏令时测试保留以支持未来地区扩展。

14.5 降级矩阵

故障	保留能力	禁止/降级
推荐服务异常	时间/地区基础流	个性化关闭并明确不影响报名
Redis 异常	PostgreSQL 权威读写	关闭热点缓存，限流转本地保守值
队列积压	核心交易继续，Outbox 留存	Push/邮件延迟，后台显示积压

故障	保留能力	禁止/降级
图片服务异常	文本与默认分类封面	暂停新图片处理，不阻断草稿文本
短信供应商异常	已验证用户正常使用	新验证显示服务状态与稍后重试
Apple 商店异常	免费功能和既有余额	暂停新购买，不重复轮询交易
WebSocket 异常	Pull/短轮询同步	实时提示降级，不影响权威写入

15. 埋点、监控与数据治理

15.1 事件命名

事件采用 domain_object_action，属性使用稳定 Schema。例如：
discovery_event_impression、event_detail_viewed、registration_submitted、
registration_confirmed、attendance_checked_in、wallet_purchase_completed。每个
事件包含 eventId、anonymousUserId/userId、sessionId、deviceId、platform、
appVersion、occurredAt、traceId 和 Schema Version。

15.2 核心漏斗

漏斗	事件链
参与者	曝光 → 详情 → 登录 → 手机验证 → 提交报名 → 成功 → 签到 → 反馈 → 60 日复购
局头	进入发布 → 草稿 → 提交审核 → 通过 → 首次报名 → 完成 → 二次发布
群组	查看 → 申请/加入 → 浏览活动 → 首次报名 → 30 日活跃 → 退出
积分	获得 → 查看钱包 → 消耗 → 余额不足 → 购买页 → 购买成功 → 再次消耗
传播	生成分享 → 外部打开 → 详情 → 报名 → 签到

北极星指标：完成一次线下活动后，在 60 天内再次参加或发起活动的真实用户数。所有实验不得以降低安全、隐私或法定义务作为对照组。

15.3 技术监控

- RED：请求速率、错误率、延迟；USE：资源利用率、饱和、错误。
- 业务不变量：超卖计数、重复签到、账本不平、负总余额、过期候补 Offer、Outbox 延迟、同步游标错误。
- 每个关键写入 Trace 包含 API → PostgreSQL → Outbox → Worker → APNs/邮件；日志使用结构化 JSON。

- Sentry/等价工具上传去敏错误；Source Map 与 dSYM 有访问控制；崩溃上下文不包含手机号、地址、验证码、投诉正文。

15.4 告警与看板

告警	阈值示例	响应
报名 5xx	5 分钟 > 1%	SEV-1，停止相关发布开关/回滚
账本不平	任意非零	SEV-0，冻结积分写入并调查
Outbox 延迟	p95 > 60s 持续 10 分钟	扩 Worker、检查队列/消费者
同步失败	同版本 iOS > 3%	检查 Schema/迁移，远程关闭新能力
OTP 发送失败	> 10%	切换供应商/降级提示
后台敏感导出异常	非工作时段或批量激增	安全告警与会话冻结复核

16. 测试与质量保证

16.1 测试金字塔

- 单元测试：状态转换、积分分配、时间规则、权限 Policy、格式与本地 Reducer。
- 属性/生成测试：账本恒等式、报名容量、候补排序、重复回调、随机操作序列不破坏不变量。
- 集成测试：真实 PostgreSQL/Redis/Queue 容器，验证事务、索引、迁移、Outbox 与 RLS。
- 契约测试：OpenAPI Schema、生成客户端、向后兼容、错误码与 `availableActions`。
- UI 测试：iOS XCUITest 与 Web Playwright 覆盖主路径、权限、断网、深链、辅助功能。
- 端到端：从 Web 发布到 iOS 报名/签到，再回 Web 复盘与运营审核。
- 非功能：负载、故障注入、恢复、安全、隐私、无障碍、国际化、商店 Sandbox。

16.2 核心并发测试

场景	注入	通过条件
最后 1 个名额	500 并发报名	恰好一个确认，其余候补/满员，无重复扣分
重复点击报名	同幂等键 20 次	返回同一业务结果与 response snapshot
不同请求复用幂等键	请求体不同	409 <code>IDEMPOTENCY_KEY_REUSED</code>
候补过期	多 Worker 同时处理	只产生一个下一位 Offer
StoreKit 重复回调	同 notification 100 次	只记账一次，回调均安全响应
离线签到重放	局头多设备重复上传	同报名只一条有效签到，审计保留重复尝试
活动取消竞态	报名与取消同时	最终无有效新报名，积分处理可证明

16.3 同步测试矩阵

- Web 修改资料 → iOS 在线、后台、离线后重连。
- iOS 收藏 → Web 多标签页；一端取消、一端重复收藏。
- 两端同时编辑活动草稿相同字段与不同字段。

- Cursor 分页中途崩溃、应用部分数据失败、游标过期、变更 Tombstone。
- 用户退出/换号/注销/受限时敏感缓存与 WebSocket 订阅清理。
- API 新增字段、枚举未知值、旧 App 版本与新服务端并存。
- 设备时间错误 24 小时、时区切换、跨日活动、日本自然日签到。

16.4 验收环境与数据

- Local：开发个人数据集，不连接生产第三方。
- Integration：每个 PR 独立数据库或 Schema，自动迁移与清理。
- Staging：与生产拓扑相似，使用 Sandbox APNs/StoreKit/短信测试号。
- Pre-Production：发布候选、生产配置镜像但无真实个人数据。
- Production：只允许合成探针与受控测试账号；不得用真实用户验证功能。

测试数据生成器覆盖：访客、未验证、已验证、受限、局头、群主、运营；免费/收费、高风险、满员、候补、取消、下架、跨日活动；正/负积分与退款；四种语言与超长文本。禁止把真实用户数据库复制到非生产环境。

16.5 发布门禁

- 编译、Lint、单元、集成、契约、迁移 Dry Run 全绿。
- P0 端到端、并发与账本不变量通过。
- iOS 无新增高优先级崩溃、主线程违规和严重无障碍缺陷。
- Web Core Web Vitals 与视觉回归在预算内。
- 依赖、容器、Secret、SAST/DAST 无未接受的 Critical/High。
- 功能开关、监控、告警、回滚、客服脚本与 App Review Notes 就绪。
- 产品、设计、QA、安全/合规按发布清单签字。

17. DevOps、迁移与发布

17.1 CI/CD 流程

```
Pull Request
→ static checks / unit tests
→ API contract compatibility
→ PostgreSQL migration up/down safety audit
→ integration + security scan
→ preview environment / iOS test build
→ e2e + visual + accessibility
→ approval
→ staged production deploy
→ smoke + SLO watch
→ gradual feature enablement
```

17.2 数据库迁移规则

- 迁移只追加，已部署 Migration 不修改；每个 PR 标注锁风险、预计时长、回滚/前滚策略。
- 使用 Expand/Contract：先加兼容字段/表 → 双写/回填 → 切读 → 停旧写 → 后续版本删旧结构。
- 大表新增非空列使用可空 + 分批回填 + 约束验证；索引使用并发创建（平台允许时）。
- 禁止发布中执行不可控全表更新、长事务或重写大表；回填 Worker 可暂停、可续跑、可监控。
- 生产迁移前在匿名化规模副本上演练并记录真实时间。

17.3 发布策略

- Backend 先向后兼容部署；Web 随后；iOS 通过 TestFlight 分层，服务端至少兼容当前与前两个活跃版本。
- 功能开关默认关闭，按内部账号 → 1% → 10% → 50% → 100% 扩大；关键指标异常自动/人工停止。
- iOS 强制更新只用于严重安全或不可兼容问题；普通版本使用温和提示。
- Web 使用蓝绿/金丝雀部署；错误率和延迟超阈值自动回滚镜像。
- 商业化配置回滚只停止新交易，不改写已完成交易；Quote 有效期内保持确认价格。

17.4 备份与灾难恢复

- RDS 自动备份 + WAL/PITR，保留期建议 35 天；每日快照按策略跨账号保存。

- S3 开启版本控制与生命周期；Restricted Bucket 启用对象锁是否适用由合规评估。
- 每季度恢复 PostgreSQL 到隔离环境，运行账本、报名、签到和外键一致性校验。
- 每半年执行区域级桌面/实战演练，验证 DNS、Secret、队列、对象存储、APNs 回调和客服流程。
- 灾难恢复后先只读验证，再开放登录、浏览，最后逐步恢复报名、积分和后台高风险写入。

17.5 运行手册

至少准备：报名错误率升高、容量锁竞争、积分不平、StoreKit 回调积压、Push 延迟、短信故障、数据库故障切换、同步游标异常、CDN 未失效、举报证据越权、运营账号被盗、紧急活动下架等 Runbook。每份 Runbook 包含触发信号、影响判断、止血、诊断、恢复、验证和升级联系人。

17.6 持续开发与技术生命周期

项目采用“稳定主线 + 持续升级”而不是一次性交付：

- Monorepo 保存 Web、Backend、OpenAPI、Design Tokens、Infrastructure 与文档；iOS 同仓但保持独立构建边界。使用 CODEOWNERS 和模块依赖检查防止跨域耦合。
- Trunk-based development，短生命周期分支；主分支始终可发布。每个功能使用服务器功能开关隔离未完成能力。
- Swift Package、npm、容器、GitHub Actions 等依赖由 Renovate/Dependabot 建立分组 PR；Patch 自动测试后快速合并，Minor 月度窗口，Major 半年评审。
- Node.js 只使用 LTS；PostgreSQL 只使用正式稳定主版本；Xcode/Swift 跟随 Apple 正式工具链，不在生产使用 Beta SDK。
- 每年安排两次 Architecture Fitness Review：模块耦合、慢查询、索引、数据增长、同步变更大小、依赖健康、SLO 与成本。
- API 向后兼容当前与前两个活跃 iOS 版本；删除字段先标记 Deprecated、监控使用量、经过至少一个完整发布周期后移除。
- 数据库 Migration、OpenAPI、错误码、埋点 Schema 和配置 Key 都有所有者与版本；禁止“临时字段”无期限存活。
- 新模块使用脚手架生成标准目录、日志、Trace、健康检查、测试与文档，减少不同团队各自发明框架。

- ADR、Runbook、数据字典、流程图和验收证据与代码一起 Review；没有更新文档的破坏性变更更不能合并。

17.7 技术债务与成本治理

- 每个迭代预留 15%–20% 容量用于升级、性能、可观测与技术债务；P0 技术债务有明确 Owner 和期限。
- 云成本按环境、模块和业务标签分摊；监控数据库、NAT、CDN、日志、图片和通知单用户成本。
- 只有在证据满足拆分条件时引入新服务：独立扩缩容收益显著、故障隔离刚需、数据所有权稳定、团队可独立值守。
- 不以微服务数量、第三方 SDK 数量或新框架数量作为“高级”指标；高级来自正确性、体验、可演进和可运营。

18. 个人开发路线与交付门禁

18.1 里程碑（推荐依赖顺序）

阶段	进入下一阶段前必须完成	交付
0 基线与原型	产品边界与关键风险已定	ADR、设计令牌、OpenAPI 骨架、Schema v0、关键原型
1 平台底座	身份与跨端同步闭环通过	手机验证、PostgreSQL、同步框架、设计系统、CI/CD
2 发现与发布	活动创建到公开可见闭环通过	发现/搜索/详情、活动草稿/审核、图片、Web 公开页
3 报名与履约	容量并发与幂等压测通过	报名、候补、通知、签到、局头工作台
4 社群与安全	举报、审计与权限验收通过	群组、反馈、举报、运营后台、权限审计
5 积分与商业化	账本不变量、对账与退款通过	双账本、配置、StoreKit Sandbox、对账与退款
6 稳定与上线	全部 P0 发布门禁通过	全链路测试、无障碍、性能、安全、恢复演练、App Review

以上是依赖顺序而不是单人开发工期承诺。一次只推进一个可上线的纵向切片；P0 验收、同步正确性、积分账本、安全和恢复演练不得因进度压缩。需要缩小首发范围时，优先关闭 P1/P2、AI 海报、成就分享与增强数据。

18.2 Definition of Ready

- 用户故事有需求编号、原型、状态、字段、权限、错误与验收。
- API/数据变更有 Schema、兼容策略、隐私等级、埋点和回滚。
- 商业化/合规功能有审核人和来源链接；数值已进入配置中心。
- 设计覆盖 Loading、Empty、Error、Offline、Permission、Dark Mode、Dynamic Type。

18.3 Definition of Done

- 代码 Review、自动化测试、契约、迁移与安全扫描通过。

- iOS 与 Web 同一账号跨端状态验证通过。
- 埋点、日志、指标、告警、审计与客服可观测。
- 文案、本地化、无障碍、隐私与错误恢复完整。
- 功能开关、回滚、Runbook 和发布说明更新。
- 对应需求追踪项与验收证据已链接。

19. 主要风险与缓解

风险	概率/影响	缓解
活动名额并发超卖	中/高	PostgreSQL 行锁、唯一约束、并发压测、容量不变量告警
积分双账本错账	中/极高	双分录、幂等、冲正、对账、人工审批、失败冻结
多端草稿覆盖	高/中	baseVersion、字段级差异、恢复点、明确冲突 UI
iOS/Web 规则漂移	中/高	服务端状态机、availableActions、OpenAPI、契约测试
Luma 风格过度相似	中/高	独立品牌令牌、差异化评审、禁止资产/布局复刻
App Review 拒绝	中/高	StoreKit、清晰资金边界、演示账号、Review Notes、预审
日本隐私/积分合规变化	中/高	上线前专业复核、配置开关、数据清单、可关闭商业化
精确地址泄露	低/极高	服务端字段级授权、加密、缓存隔离、自动化越权测试
通知风暴	中/中	聚合、频控、幂等 Delivery、静默时段、用户偏好
运营高权误操作	中/高	最小权限、双人审批、Revision、重新认证、完整审计
搜索跨语言效果差	中/中	trigram/别名/人工词典、查询分析、达到阈值再引入搜索集群
模块化单体退化	中/中	Schema 所有权、依赖规则、模块契约测试、定期架构审查

20. 验收与需求追踪

20.1 顶级追踪矩阵

产品基线	技术实现章节	核心验收证据
A/B 文档、角色权限	2、5、13	Policy 单测、角色 E2E、审计日志
C 账号系统	4、8、9、11	访客浏览、登录合并、+81 验证、注销 E2E
D 发现搜索收藏	3、4、7、10	组合筛选、地图、缓存、跨端收藏同步
E 活动发布	4、8、11、12	草稿恢复、风险审核、积分 Hold、关键变更通知
F 报名候补签到	6、8、11、12、16	500 并发、候补顺序、动态码、补签、积分不重复
G 群组	7、8、11	容量、权限、扩容、转让、解散审计
H 成就	7、11、15	规则版本、授予/撤回、隐私隐藏
I/J 积分与资金边界	7、9、11、13	双账本、StoreKit、退款、外部活动费隔离
K/L 通知分享	5、10、11、15	频控、静默、关键通知、Universal Link、归因
M 安全举报	7、11、13	举报匿名、证据权限、SLA、下架/申诉
N/O 商业化与后台	10、11、13	功能开关、审批、脱敏、导出审计
P 埋点指标	15	Schema 校验、漏斗、隐私过滤、业务看板
Q/R 非功能异常	6、14、16、17	性能、恢复、弱网、幂等、降级演练
S/T 发布开关验收	17、18、20	灰度、回滚、发布门禁、逐项确认

20.2 P0 上线验收场景

- 访客从分享链接进入 Web 活动详情，无登录即可查看公开信息；报名时登录并验证日本手机号，iOS 登录同账号后看到已报名状态。
- iOS 创建活动草稿，Web 工作台继续编辑并提交；iOS 收到审核状态更新，草稿字段与版本一致。
- 最后一个名额同时收到多端报名，仅一个确认，其余获得候补选择；钱包无重复扣分。

4. 局头取消活动，公开页快速变为取消，所有报名/候补收到站内记录，报名积分按规则退回，活动费提示联系局头。
5. 动态二维码签到后 Web 工作台实时看到到场，用户获得一次到场奖励和评价资格；重复扫码不重复发放。
6. 群组满 50 人后新增加入失败但现有成员正常；积分扩容成功后允许新增，扩容交易与审计一致。
7. 运营下架高风险活动，公开页、分享、报名、iOS 缓存均收敛为不可用；精确地址从未授权响应与缓存移除。
8. Apple 商店重复交易回调只发放一次；退款生成冲正，负付费积分限制只影响配置的高风险能力。
9. PostgreSQL 恢复演练后账本、报名、签到、Outbox 和同步游标一致；RPO/RTO 达标。
10. 所有 P0 核心页面通过中文/日文长文本、深色模式、Dynamic Type、VoiceOver/键盘与弱网测试。

20.3 上线自检清单

- 产品视角：P0 范围、状态规则、积分配置、收费边界、客服文案。
- 设计视角：Spott 独立设计语言、全状态、响应式、暗色、无障碍。
- iOS 实现：原生能力、同步、StoreKit、推送、隐私清单、Review Notes。
- Web 实现：SEO、Universal Link、缓存失效、CSP、PWA 敏感缓存。
- 后端实现：PostgreSQL 约束、幂等、状态机、Outbox、对账、限流。
- 质量验证：E2E、并发、恢复、安全、兼容、无障碍证据。
- 运行保障：SLO、告警、备份、恢复、Runbook、应急联系路径。
- 安全与合规：APPI、App Review、数据清单、供应商、未成年人、积分与活动费边界。

附录 A. 配置中心键建议

Key	示例	说明
points.reward.phone_verified	500	首次验证奖励
points.reward.profile_completed	100	资料完成奖励
points.cost.registration	10	报名消耗
points.cost.event_publish	100/120	按阶段配置
points.free.daily_detail_views	10	稳定期免费详情次数
event.max_capacity.default	500	超出进入大组织者方案
registration.cancel_refund_hours	24	开始前退积分门槛
checkin.window.before_minutes	60	默认签到开始窗口
checkin.window.after_minutes	120	默认签到结束窗口
attendance.correction_hours	48	补签申请期
notification.quiet_hours	22:00-08:00	日本时区普通通知静默
group.initial_capacity	50	初始容量
group.capacity_increment	50	每档扩容
sync.change_retention_days	90	游标变更保留

附录 B. 稳定错误码目录

域	错误码	用户行动
Auth	PHONE_VERIFICATION_REQUIRED	继续验证
Auth	PHONE_ALREADY_BOUND	账号合并或申诉
Auth	OTP_RATE_LIMITED	显示可重试时间
Event	EVENT_REVIEW_REQUIRED	查看审核状态
Event	EVENT_KEY_FIELDS_CHANGED	重新确认
Registration	REGISTRATION_CAPACITY_FULL	加入候补
Registration	WAITLIST_OFFER_EXPIRED	返回候补状态
Checkin	CHECKIN_WINDOW_CLOSED	申请补签
Points	POINTS_INSUFFICIENT	显示需要/现有/获取方式
Points	POINTS_ACCOUNT_RESTRICTED	补足或申诉
Sync	VERSION_CONFLICT	比较云端与本地版本
Sync	CURSOR_EXPIRED	受控快照重建
Safety	CONTENT_REMOVED	查看规则与申诉

附录 C. 外部参考与复核日期

以下参考仅用于提炼产品原则和实现约束，不能作为复制第三方产品的许可。所有链接均应在上线前再次复核。

- Luma Discover: <https://luma.com/discover> (复核: 2026-07-15)
- Luma iOS App Help: <https://help.luma.com/p/luma-ios-app> (复核: 2026-07-15)
- Luma Creating an Event: <https://help.luma.com/p/creating-an-event> (复核: 2026-07-15)
- Luma Discovering Events: <https://help.luma.com/p/discovering-events> (复核: 2026-07-15)
- Apple App Review Guidelines: <https://developer.apple.com/app-store/review/guidelines/> (复核: 2026-07-15)
- Apple App Store Server Notifications:
<https://developer.apple.com/documentation/storekit/enabling-app-store-server-notifications> (复核: 2026-07-15)
- Apple Xcode Releases (Xcode 26.6) :
<https://developer.apple.com/news/releases/?id=06252026a> (复核: 2026-07-15)
- Swift 6.3 Release: <https://www.swift.org/blog/> (复核: 2026-07-15)
- Next.js 16.2 Stable: <https://nextjs.org/blog> (复核: 2026-07-15)
- React 19.2: <https://react.dev/blog/2025/10/01/react-19-2> (复核: 2026-07-15)
- TypeScript 6.0: <https://www.typescriptlang.org/docs/handbook/release-notes/typescript-6-0.html> (复核: 2026-07-15)
- Node.js Releases (24 LTS) : <https://nodejs.org/en/about/previous-releases> (复核: 2026-07-15)
- NestJS 11 Migration Guide: <https://docs.nestjs.com/migration-guide> (复核: 2026-07-15)
- PostgreSQL 18 Documentation: <https://www.postgresql.org/docs/current/> (复核: 2026-07-15)
- 日本个人信息保护委员会 APPI 指南:
https://www.ppc.go.jp/personalinfo/legal/guidelines_tsusoku/ (复核: 2026-07-15)
- Noto CJK 字体与 SIL Open Font License: <https://github.com/notofonts/noto-cjk> (复核: 2026-07-15;
DOCX 嵌入 Noto Sans SC 以保证跨平台中文显示)

附录 D. 最终技术原则

1. PostgreSQL 保存事实，客户端缓存保存体验；二者不可颠倒。
2. WebSocket 提供及时性，增量 Pull 提供可靠性；二者不可替代。
3. 关键状态由服务端状态机决定，客户端只展示可行动作。
4. 幂等键防重复，数据库约束守底线，审计日志解释发生了什么。
5. 活动费与平台积分在产品、代码、账本和文案上彻底隔离。
6. 视觉借鉴高级感与内容优先，不借用第三方身份；Spott 必须一眼有自己的城市气质。
7. 所有商业化能力先可配置、可灰度、可回滚，再考虑放大。
8. 如果同步、积分、安全或隐私无法被测试证明，就不能视为完成。